Diterjemahkan dari bahasa Inggris ke bahasa Indonesia - www.onlinedoctranslator.com

Jurnal Internasional Sistem Informasi Akuntansi 51 (2023) 100642

Daftar isi tersedia diSains Langsung

Jurnal Akuntansi Internasional Sistem Informasi

Halaman utama jurnal:www.elsevier.com/locate/accinf

Model alur menuju lima jalur akuntabilitas dalam tata kelola keamanan siber

Sergeja Slapničar*, Michael Axelsen , Ivano Bongiovanni , David Stockdale

Universitas Queensland, 4067 St Lucia, Australia

INFORMASI ARTIKEL

Kata kunci:
Manajemen risiko siber
Tata Kelola Keamanan Siber
Lima Garis Akuntabilitas Teori Institusional
Kerangka kerja efisiensi terbatas

ABSTRAK

Dalam studi lapangan mendalam, kami menyelidiki konfigurasi tata kelola keamanan siber terkait dengan lima jalur akuntabilitas (5 LoA) – yaitu, Model Tiga Jalur yang diperluas dengan akuntabilitas manajemen eksekutif dan dewan direksi (IIA, 2020Tujuan penelitian ini adalah untuk mengeksplorasi konfigurasi yang diadopsi oleh organisasi dalam mengatur keamanan siber, dan mengapa penerapan lima jalur akuntabilitas (5 LoA) penting bagi keamanan siber. Kami mendefinisikan jenis adopsi 5 LoA berdasarkan: (i) pemisahan jalur yang berkisar dari campuran hingga terpisah dan (ii) tingkat keterlibatan mereka yang berada dalam peran jalur yang berkisar dari rendah hingga tinggi. Dengan cara ini, kami mengidentifikasi empat jenis adopsi 5 LoA: 'tidak ada adopsi', 'tampak', 'implisit', dan 'eksplisit'. Kami membuat teori tentang bagaimana jenis adopsi 5 LoA dipengaruhi oleh interaksi kekuatan kelembagaan dan kebutuhan organisasi akan efisiensi dan efektivitas, dan mengembangkan model jalur untuk adopsi 5 LoA oleh organisasi. Kami menemukan bahwa organisasi yang mengadopsi 5 LoA dengan pemisahan yang jelas antara garis-garis ini ('adopsi yang tampak' dan 'eksplisit') adalah organisasi yang tunduk pada regulasi kehati-hatian (kekuatan koersif), sedangkan motif efisiensi dan kekuatan mimetik mendorong organisasi untuk mencari fluiditas dan fleksibilitas dengan 'mencampur' garis-garis yang dipisahkan ('adopsi implisit') untuk memastikan reaksi cepat terhadap perubahan lingkungan. Terlepas dari pemisahan antara garis-garis dan apakah garis-garis tersebut dicampur atau tidak, kami menemukan bahwa semua organisasi melihat ruang lingkup untuk meningkatkan tingkat keterlibatan dalam 5 LoA untuk meningkatkan efektivitas tata kelola keamanan siber.

1. Pendahuluan

Risiko keamanan siber (CS) termasuk di antara risiko bisnis yang paling mendesak dalam ekonomi digital.Forum Ekonomi Dunia, 2023Meskipun terjadi peningkatan yang stabil dalam investasi CS oleh organisasi sektor publik dan swasta (KPMG, 2019), kejahatan siber sedang meningkat (Lee, 2021 Fenomena global seperti pandemi COVID-19 telah memperburuk risiko CS karena karyawan semakin banyak bekerja jarak jauh menggunakan jaringan dan perangkat di luar kendali organisasi.Ali dkk., 2020; Škiljić, 2020).

Meskipun pengakuan umum bahwa CS (Critical Secretary) merupakan masalah bisnis dan bukan semata-mata masalah teknologi informasi (TI), tata kelola CS hanya mendapat sedikit perhatian penelitian dibandingkan dengan penelitian ekstensif yang mempelajari sisi teknis CS. Tata kelola CS membahas bagaimana organisasi mendelegasikan wewenang pengambilan keputusan dari Dewan Direksi (BoD) ke berbagai tingkat operasional dan manajerial untuk memastikan kerahasiaan, integritas, dan ketersediaan aset digital organisasi.Lyons, 2011; ISO/IEC 27014; 2013Tata kelola CS memiliki implikasi yang jelas terhadap manajemen risiko CS, yang berkaitan dengan risiko keamanan informasi.

* Penulis korespondensi.
*Alamat email:*s.slapnicar@uq.edu.au (S. Slapničar),m.axelsen@uq.edu.au (M. Axelsen),i.bongiovanni@uq.edu.au (I. Bongiovanni), d.stockdale@uq.edu.au (D. Stockdale).

https://doi.org/10.1016/j.accinf.2023.100642
Diterima 28 Februari 2022; Diterima dalam bentuk revisi 23 Februari 2023; Diterima 20 Juli 2023;
Tersedia daring 7 Agustus 2023
1467-0895/© 2023 Para Penulis. Diterbitkan oleh Elsevier Inc. Artikel ini merupakan artikel akses terbuka di bawah lisensi CC BY-NC-ND. (http://creativecommons.org/licenses/by-nc-nd/4.0/).

muncul*"Secara khusus, ini merujuk pada ancaman dan kerentanan yang terkait dengan koneksi dan penggunaan dunia maya. Ini mengacu pada proses dan kontrol yang diterapkan oleh suatu entitas untuk mengelola risiko keamanan siber.*(AICPA, 2017Dengan kata lain, tata kelola CS adalah istilah umum untuk arahan strategis dan pengawasan Dewan Direksi terhadap manajemen risiko siber dan implementasi operasionalnya.

Tata kelola dan manajemen risiko CS sangat dipengaruhi oleh pedoman praktisi (Institut Auditor Internal [IIA], 2016) daripada berdasarkan wawasan dari penelitian akademis. Organisasi profesional (Komite Organisasi Sponsor Komisi Tredway (COSO), 2004; 2013; 2017; IIA, 2013; 2016; 2020), regulator keuangan (Prinsip-prinsip Pengelolaan Risiko Operasional yang Baik dari Komite Basel tentang Pengawasan Perbankan, 2011; 2021), asosiasi manajemen risiko (ISACA), dan perusahaan konsultan besar secara intensif mempromosikan model tiga lini pertahanan (3 LoD) dalam manajemen risiko.

Salah satu kritik terhadap model 3 LoD adalah fokus pada 'pertahanan' dan kecenderungan manajemen risiko untuk menjadi 'Kantor Penolakan', alih-alih membantu manajemen dalam menghadapi ketidakpastian.Leech dan Hanlon, 2016Kritik lebih lanjut adalah bahwa 3 LoD tidak secara eksplisit mengakui peran manajemen eksekutif dan Dewan Direksi (Lyons, 2011; Leech dan Hanlon, 2016Faktanya, gugatan-gugatan terkenal terkait insiden siber justru ditujukan kepada Dewan Direksi dan manajer eksekutif, yang menunjukkan bahwa para pemangku kepentingan memandang mereka sebagai pihak yang paling bertanggung jawab.Leech dan Hanlon, 2016Keterlibatan Dewan Direksi dan manajemen eksekutif dalam keamanan siber telah dianjurkan setidaknya selama dua dekade (Kerangka kerja NIST 2018; COBIT, 2019; Lyons, 2011; Protiviti, 2013).

Sebagai tanggapan, IIA mengakui adanya lapisan tambahan dalam manajemen dan tata kelola risiko siber, dan bahwa untuk menciptakan nilai, suatu organisasi perlu menerima dan mengelola berbagai tingkat risiko. Akibatnya, IIA menghilangkan istilah 'pertahanan' dan mengakui peran khusus para manajer eksekutif dan dewan direksi dalam Model Tiga Garis (TLM) yang telah diperbarui. Sementara itu,IIA (2020)Dengan tetap merujuk pada TLM yang diperbarui, model ini sebenarnya mengidentifikasi lima jalur akuntabilitas. Ini adalah jalur pertama, kedua, dan ketiga dari 3 LoD serta jalur manajemen dan Dewan Direksi. Kami menyebut TLM yang diperbarui sebagai model 5 LoA untuk menekankan perbedaan ini.

Dibandingkan dengan model 3 LoD tradisional, model baru ini memungkinkan fleksibilitas yang lebih tinggi dalam desain lini, mengacu pada kerja sama erat dan bahkan integrasi di antara lini-lini tersebut, serta menekankan tanggung jawab para aktor tata kelola yang relevan.Eulerich, 2021Sejauh pengetahuan kami, model 5 LoA adalah satu-satunya kerangka kerja profesional preskriptif yang melembagakan konfigurasi tata kelola yang membentuk hubungan antara Dewan Direksi, manajer eksekutif, dan mereka yang berada di organisasi yang menangani manajemen risiko keamanan siber. Meskipun keterlibatan di semua tingkatan di seluruh hierarki organisasi merupakan tema umum dalam kerangka kerja nasional serupa, model 5 LoA mewakili standar praktik terbaik dan pendekatan efisien untuk meringkas keterlibatan organisasi yang komprehensif yang disarankan oleh organisasi profesional dan akademisi. Mengingat kekosongan regulasi tentang tingkat keterlibatan Dewan Direksi yang dibutuhkan dalam keamanan siber, pedoman dari organisasi terkemuka di bidang ini sangat baru: Australian Institute of Company Directors (AICD) dan CS Cooperative Research Centre baru pada Oktober 2022 menerbitkan serangkaian pedoman untuk membantu para direktur di dewan direksi Australia mengawasi manajemen risiko siber.Pusat Penelitian Kooperatif AICD & CS, 2022).

Bukti deskriptif menunjukkan bahwa organisasi mungkin tidak selaras dengan model yang diperbarui: lebih dari 60% organisasi menugaskan akuntabilitas untuk CS kepada fungsi TI (ACCA dan CAANZ, 2019Hanya sekitar sepertiga dari organisasi besar yang menganggap manajemen risiko siber sebagai tanggung jawab jajaran manajemen puncak (C-suite). Lebih lanjut, 59% organisasi mengatakan bahwa hubungan antara keamanan siber dan berbagai area organisasi paling baik bersifat netral, tetapi lebih mungkin tidak saling percaya atau tidak ada sama sekali, dan 60% organisasi tidak memiliki spesialis keamanan siber yang akan duduk di dewan direksi atau di tingkat manajemen eksekutif.EY dan IIA, 2021).

Meskipun serangan siber terus meningkat, keberhasilan badan pemerintahan dalam menangani risiko siber dan pelanggaran keamanan relatif belum diketahui.Hartmann dan Carmenate, 2021Tidak ada bukti penelitian mengenai struktur tata kelola CS mana yang diadopsi dalam praktik, dan bagaimana berbagai lini berkolaborasi dan saling memantau satu sama lain.[1]

Dalam penelitian ini, tujuan kami adalah untuk mengeksplorasi konfigurasi yang diadopsi oleh organisasi dalam mengatur keamanan siber, mengapa penting bagi keamanan siber apakah lima jalur akuntabilitas diadopsi, dan faktor-faktor apa yang memengaruhi adopsinya. Untuk menjawab tujuan ini, kami menggunakan kerangka kerja efisiensi terbatas (Roberts dan Greenwood, 1997) yang berpendapat bahwa organisasi menyeimbangkan efisiensi dan tekanan kelembagaan dalam keputusan mereka untuk mengadopsi model tata kelola tertentu. Kerangka kerja ini mengintegrasikan teori biaya transaksi dan teori kelembagaan. Teori biaya transaksi (Coase, 1937; Williamson, 1975) berpendapat bahwa motif mendasar organisasi dalam memilih struktur tata kelolanya adalah efisiensi, dan bahwa organisasi berupaya mengoptimalkan struktur dan proses untuk efektivitas dalam batasan kelembagaan yang diberikan. Teori kelembagaan menunjukkan bahwa dalam menghadapi ketidakpastian, organisasi cenderung mengadopsi pendekatan yang 'dianggap sudah pasti' untuk melegitimasi (DiMaggio dan Powell, 1983; Lawrence dan Shadnam, 2008; Jeyaraj dan Zadeh, 2020 Kerangka kerja konsolidasi berpendapat bahwa efisiensi dan efektivitas tata kelola keamanan siber bukanlah satu-satunya perhatian organisasi. Bagi mereka, penting juga agar tata kelola keamanan siber mereka sah. Kami meneliti bagaimana motif efisiensi dan efektivitas diseimbangkan dengan kekuatan kelembagaan dalam konfigurasi 5 LoA.

Berdasarkan premis teoritis tersebut, kami merumuskan dua pertanyaan penelitian

(RQ): *RQ1: Bagaimana konfigurasi tata kelola CS terkait dengan lima jalur akuntabilitas?*

RQ2: Mengapa penerapan lima jalur akuntabilitas itu penting?

Karena organisasi jarang memberikan informasi publik mengenai pendekatan mereka terhadap tata kelola tanggung jawab sosial perusahaan (CSR), kami melakukan studi eksplorasi untuk menjawab pertanyaan penelitian melalui penelitian lapangan dalam konteks organisasi yang berbeda. Kami melakukan 24 wawancara dengan responden yang berada di posisi penting dalam tata kelola CSR dan manajemen risiko di lima organisasi besar dan terekspos di berbagai industri. Salah satu peserta adalah bank Eropa di mana struktur TLM yang diperbarui diwajibkan oleh peraturan. Kami mengadopsi pendekatan konstruktivis (Lincoln dkk., 2011) dan menerapkan metode analisis kualitatif dariGioia dkk. (2013)untuk lebih memahami tata kelola dan manajemen risiko tanggung jawab sosial perusahaan (CSR). Oleh karena itu, kami mengembangkan dan menyajikan pemahaman tentang tata kelola dan manajemen risiko CSR yang didasarkan pada pengalaman mereka yang memiliki peran di bidang tersebut.

[1]KecualiSteinbart dkk. (2018)yang mempertimbangkan kolaborasi lini kedua dan ketiga.

menopang mereka.

Makalah ini memberikan kontribusi pada literatur tata kelola tanggung jawab sosial perusahaan (CSR) dan manajemen risiko yang sedang berkembang dalam beberapa hal. Pertama, penelitian tentang tata kelola CSR yang mempertimbangkan tanggung jawab CSR berdasarkan fungsi organisasi relatif sedikit dan berfokus pada jalur akuntabilitas individu.[2]berbeda dengan struktur secara keseluruhan. Namun, Manajemen Risiko Perusahaan (ERM) bukanlah proses yang sepenuhnya serial (Walton dkk., 2021) dan 5 LoA tidak ortogonal, tetapi saling terkait. Studi kami membahas kebutuhan untuk menyelidiki fungsi gabungan dari 5 LoA dengan menguraikan akuntabilitas yang diberikan organisasi kepada berbagai peran, bagaimana peran-peran ini berinteraksi untuk memajukan CS (Wilkin dan Chenhall, 2020; Eulerich, 2021), dan yang memiliki wewenang formal dan informal atas pengambilan keputusan CS (Aghion dan Tirole, 1997). Dalam mempelajari*jenis adopsi 5 LoA*Dalam konfigurasi tata kelola CS, kami mengembangkan skala dua dimensi yang didefinisikan oleh (i) pemisahan lini dan (ii) tingkat keterlibatan dalam peran yang terdapat dalam 5 LoA. Kami mengidentifikasi empat jenis adopsi termasuk adopsi 'tidak', 'tampak', 'implisit', dan 'eksplisit'. Kedua, studi kami mengembangkan *model faktor*mempengaruhi konfigurasi tata kelola CS dan adopsi struktur 5 LoA dengan mengusulkan bagaimana faktor-faktor kelembagaan (DiMaggio dan Powell, 1983; Jeyaraj dan Zadeh, 2020) dan motif efisiensi/efektivitas berinteraksi dalam konfigurasi struktur tata kelola CS (CS governance structures).Roberts dan Greenwood, 1997Ketiga, kami mengembangkan sebuah*model jalur*tentang bagaimana konfigurasi tata kelola CS berkembang dari waktu ke waktu. Model ini mempertimbangkan interaksi antara kekuatan kelembagaan dan motif efisiensi/efektivitas untuk memberikan wawasan tentang sifat evolusioner dan dinamis dari tata kelola CS.

Pada bagian selanjutnya, kami menyajikan 5 Prinsip Aksi (LoA) normatif dan meninjau peran manajemen eksekutif dan Dewan Direksi yang kurang diteliti. Kemudian, kami mengidentifikasi kerangka kerja yang menjelaskan bagaimana kekuatan institusional serta motif efisiensi dan efektivitas memengaruhi adopsi 5 LoA. Pada bagian ketiga, kami menjelaskan metode kami. Bagian keempat menyajikan temuan kami dan model faktor-faktor yang memengaruhi adopsi 5 LoA. Pada bagian kelima, kami membahas temuan dan menyajikan model jalur yang menjelaskan bagaimana konfigurasi tata kelola CS berkembang dari waktu ke waktu. Kemudian, kami mengidentifikasi peluang untuk penelitian masa depan dan implikasi praktis dari temuan kami sebelum menyimpulkan makalah ini.

2. Tinjauan pustaka

2.1. Lima jalur akuntabilitas dalam tata kelola CS

Secara garis besar, tata kelola perusahaan berfokus pada hubungan antar pemangku kepentingan perusahaan. Tata kelola perusahaan menyediakan struktur akuntabilitas untuk menetapkan, mencapai, dan memantau tujuan perusahaan.OECD, 2015). CS merupakan bidang tata kelola yang sedang berkembang pesat (Sambamurthy dan Zmud, 2000; Wilkin dan Chenhall, 2020), meskipun konfigurasi tata kelola CS masih menjadi bahan perdebatan, tetapi sebagian besar dalam publikasi profesional (IIA, 2016).

Studi ini berfokus pada mekanisme tata kelola struktural dan relasional dari tata kelola TI (Van Grembergen dkk., 2004) dan dengan demikian menjawab dua pertanyaan yang berbeda namun saling terkait. Tata Kelola*struktur*berfokus pada pertanyaan, 'Siapa yang memiliki peran apa dalam pengambilan keputusan?' sementara*mekanisme relasional*Menjawab pertanyaan, 'Siapa berkolaborasi dengan siapa, dan bagaimana mereka saling memantau?' Mekanisme relasional berkaitan dengan otoritas formal dan informal (Aghion dan Tirole, 1997) dan mencakup kerja sama, dialog strategis, dan pembelajaran bersama di antara para eksekutif perusahaan, manajemen TI, dan manajemen bisnis (Peterson dan Van Grembergen, 2004; Van Grembergen dkk., 2004).

Lima Tingkat Akuntabilitas (LoA) memberikan dasar untuk mengidentifikasi struktur, peran, dan akuntabilitas yang dibutuhkan untuk tata kelola Keamanan Siber (CS). Dalam konteks CS, lini pertama adalah fungsi TI garis depan yang bertanggung jawab atas implementasi kontrol untuk melindungi organisasi dari risiko siber. Lini kedua mewakili pengawasan taktis yang bertugas menetapkan kebijakan manajemen risiko, memantau kontrol lini pertama, dan memastikan kepatuhan terhadap peraturan CS dan kebijakan manajemen risiko TI/CS. Peran lini kedua mencakup fungsi ERM, kepatuhan, keamanan, dan jaminan kualitas. Lini ketiga – fungsi audit internal – independen dari manajemen dan tidak ikut serta dalam pengambilan keputusan manajemen.Héroux dan Fortin, 2013). Ini menyediakan*"jaminan dan saran yang independen dan objektif mengenai kecukupan dan efektivitas tata kelola dan manajemen risiko"*kepada Dewan Direksi (IIA, 2020, hlm. 3Ketiga jalur tersebut tidak harus bersifat hierarkis tetapi dapat beroperasi secara bersamaan (IIA, 2020).

Manajemen eksekutif diusulkan sebagai lini akuntabilitas keempat (Eulerich, 2021; Lyons, 2011;Leech dan Hanlon, 2016; Rothrock dkk., 2018; Stafford dkk., 2018 Manajemen eksekutif memiliki tanggung jawab untuk mengelola organisasi dan mengalokasikan sumber daya untuk pengelolaan berbagai risiko. Manajemen eksekutif mengembangkan, mendukung, dan mengawasi ERM (Enterprise Risk Management).COSO, 2017) dan memastikan bahwa tiga lini pertama memiliki kompetensi yang diperlukan dan berkinerja sesuai harapan. Karena manajemen risiko siber hanyalah salah satu area ERM, manajemen eksekutif bertanggung jawab untuk menyelaraskannya dengan area lain (Deloitte, 2015).

Sebagian besar penelitian sebelumnya menemukan bahwa memiliki eksekutif (CEO, CFO, dan CIO) dengan keahlian TI atau eksekutif TI di dewan manajemen secara signifikan mengurangi pelanggaran keamanan data yang dilaporkan.Feng dan Wang, 2018; Haislip dkk., 2016; Haislip dkk., 2020; Haislip dkk., 2021; Vincent dkk., 2019; Smith dkk., 2021Salah satu pengecualiannya adalah studi tentangHaislip dkk. (2021)yang menemukan bahwa memiliki CEO dengan keahlian TI dapat menyebabkan insiden pelanggaran siber yang lebih tinggi, meskipun hal ini dianggap karena mereka lebih mungkin mendeteksi dan melaporkan pelanggaran siber.

Dewan Direksi (BoD) adalah lini akuntabilitas kelima yang mendukung selera risiko organisasi dan mengawasi apakah manajemen eksekutif beroperasi dalam batas toleransi risiko organisasi. Peran strategisnya mengharuskan BoD untuk berpartisipasi dalam mengembangkan dan menyempurnakan tujuan strategis utama (misalnya, menetapkan selera risiko) dan metrik risiko, menentukan ketelitian penilaian risiko, dan memastikan independensi penjaminan (Lintah dan Hanlon, 2016; Von Solms dan Von Solms, 2018).

[2]Contoh studi tentang peran*auditor internal*:Dzuranin dan Mălăescu, 2016;Islam dkk., 2018;Kahyaoglu dan Çaliyurt, 2018;Héroux dan Fortin, 2013; Slapničar dkk., 2022; dari*Pakar TI dan keamanan*:Kappelman dkk., 2017,Tahun 2016; dari*penyedia jaminan eksternal*:Stafford dkk., 2018; dari*pengelolaan* : misalnya,Vincent dkk., 2019;Haislip dkk., 2016;Haislip dkk., 2020;*dan Dewan Direksi*:Higgs dkk., 2016;Lankton, 2021.

Meskipun bukti menunjukkan efek yang sebagian besar positif dari manajer eksekutif dengan keahlian TI terhadap pelanggaran siber, sejumlah kecil pakar keamanan siber*tata kelola*Studi-studi yang ada tidak memberikan bukti konklusif mengenai peran dewan direksi. Penelitian sebelumnya menemukan bahwa bahkan dalam hal-hal yang jauh kurang teknis daripada manajemen dan pengawasan risiko CS, dewan direksi relatif pasif dan sebagian besar hanya terlibat dalam mencatat laporan dan pemantauan rutin.Machold dan Farquhar, 2013) daripada menantang para eksekutif (Peck, 1995; Freeman dan Peck, 2007; Parker, 2008). Paling sering, Dewan Direksi menangani pengawasan CS dalam komite khusus (biasanya TI atau audit).Higgs dkk. (2016)Penelitian menyelidiki apakah pembentukan komite TI tingkat dewan direksi menandakan kemampuan perusahaan untuk mendeteksi dan menanggapi pelanggaran keamanan dan menemukan sebaliknya. Namun, pasar bereaksi kurang negatif terhadap pelanggaran data jika suatu organisasi memiliki komite semacam itu. Hanya kurang dari setengah dewan direksi S&P yang secara jelas mendefinisikan pemantauan risiko operasional (seperti risiko siber) dalam piagam mereka (Harrast dan Swaney, 2019).Benaroch dan Chernobai (2017) Menganalisis apakah kegagalan operasional TI, yang antara lain menunjukkan pengawasan Dewan Direksi yang tidak memadai, memicu penggantian anggota dewan untuk meningkatkan kompetensi TI dewan, dan menemukan bahwa pada umumnya hanya CIO yang diganti sebagai kambing hitam kegagalan TI, dan bukan direktur non-eksekutif.Vincent dkk. (2019)Ditemukan adanya pengaruh positif dari keterlibatan Dewan Direksi dan keahlian TI-nya terhadap tingkat kematangan manajemen risiko CS.Lankton (2021)Mereka meneliti pengungkapan keterlibatan direktur dalam tata kelola TI dalam piagam audit. Mereka memperkirakan bahwa pelanggaran data akan berdampak positif pada pengungkapan tersebut, tetapi justru menemukan dampak negatif.

Dalam praktiknya, terdapat celah atau tumpang tindih antara baris pertama, kedua, dan ketiga (Soomro dkk., 2016Selain itu, saat ini terdapat kesenjangan yang signifikan antara informasi yang diberikan oleh tingkat operasional TI dan pemahaman Dewan Direksi serta para manajer eksekutif (Gale dkk., 2022Salah satu kekhawatiran adalah karena adanya ketidaksesuaian ini, tidak semua orang dalam jalur akuntabilitas menjalankan perannya secara efektif, sehingga jalur-jalur tersebut tidak selaras dan terintegrasi dengan baik. Selain itu, jalur keempat dan kelima (manajemen dan Dewan Direksi) memiliki kompetensi yang tidak memadai dan sering kesulitan memahami laporan keamanan siber, yang menyebabkan akuntabilitas yang longgar dan melemahkan tata kelola siber yang efektif.Nasdaq dan Tanium, 2016; Survei Global McKinsey, 2018Pertanyaannya kemudian adalah, sejauh mana otoritas formal mencerminkan otoritas nyata?Aghion dan Tirole, 1997).

2.2. Motif efisiensi/efektivitas versus legitimasi untuk menjelaskan adopsi 5 LoA

Dalam menjelaskan mengapa organisasi mengadopsi 5 LoA, kami mengandalkan dua teori dan kerangka kerja yang menyatukan. Yang pertama adalah teori biaya transaksi (Coase, 1937; Williamson, 1975) dengan alasan bahwa organisasi berperilaku rasional dan menerapkan struktur serta proses yang menghemat biaya transaksi dalam mendirikan perusahaan (Williamson, 2007Teori biaya transaksi memandang struktur organisasi melalui lensa ekonomi dan hukum (Williamson, 2008Pemilik perusahaan menyusun struktur organisasi untuk mengoptimalkan kinerja dan dengan demikian memaksimalkan keuntungan (Young, 2013Diterapkan pada tata kelola keamanan siber, adopsi model seperti itu akan terjadi jika model tersebut juga efisien karena selaras dengan karakteristik organisasi, lingkungan, dan struktur organisasi. Kritik umum adalah bahwa pendekatan ini merupakan penjelasan yang 'kurang tersosialisasikan' tentang apa yang sebenarnya terjadi (Granovetter, 1985; Roberts dan Greenwood, 1997; Young, 2013Artinya, teori biaya transaksi hampir tidak mempertimbangkan konteks sosial atau kelembagaan tempat organisasi beroperasi.

Teori kedua adalah teori institusional (DiMaggio dan Powell, 1983; Lawrence dan Shadnam, 2008) menunjukkan bahwa keputusan tentang praktik baru didasarkan pada praktik yang dianggap sudah lazim atau praktik yang paling dapat diterima (Roberts dan Greenwood, 1997Mengadopsi model tata kelola yang diakui dapat menjadi cara untuk*melegitimasi*pendekatan organisasi (Kekuatan, 2009), dan dalam menghadapi ketidakpastian, kebutuhan ini mungkin mendasar bagi pilihan organisasi dalam mengkonfigurasi akuntabilitas dan tanggung jawab mereka untuk tata kelola CS dan manajemen risiko. Kritik umum terhadap teori institusional adalah bahwa teori tersebut 'terlalu tersosialisasikan' (Granovetter, 1985; Roberts dan Greenwood, 1997 Artinya, teori institusional hampir tidak mempertimbangkan konteks ekonomi organisasi tersebut.

Meskipun kedua teori tersebut tampak bertentangan,Roberts dan Greenwood (1997)Para penulis menganggap kedua teori tersebut saling melengkapi karena organisasi mengoptimalkan efisiensi dan efektivitas dengan mempertimbangkan tekanan kelembagaan. Mereka mengintegrasikan kedua teori tersebut sebagai berikut:*efisiensi terbatas*kerangka kerja. Untuk memahami apakah kerangka kerja manajemen risiko dapat meningkatkan efisiensi, model yang digunakan adalah... Gordon dkk. (2009)sangat berwawasan. Para penulis ini berpendapat bahwa ERM akan berdampak positif pada kinerja perusahaan jika sesuai dengan ketidakpastian lingkungan perusahaan (misalnya, paparan risiko siber), persaingan industri, kompleksitas perusahaan, ukuran perusahaan, dan pengawasan Dewan Direksi. 5 LoA adalah*kerangka kerja manajemen risiko*Di mana pengawasan Dewan Direksi dianggap sebagai salah satu jalur akuntabilitas dan bukan sebagai faktor eksogen. Oleh karena itu, kami berpendapat bahwa organisasi yang mengejar efisiensi dan efektivitas menyesuaikan struktur tata kelolanya dengan ketidakpastian lingkungan, persaingan industri, kompleksitas perusahaan, dan ukuran perusahaan. Di bawah ini, kami membuat teori tentang bagaimana kekuatan kelembagaan memengaruhi adopsi 5 LoA dalam mengkonfigurasi tata kelola CS dan bagaimana interaksinya dengan motif efisiensi dan efektivitas.

Menurut teori institusional, hukum dan peraturan mewakili*paksaan*tekanan yang harus dipatuhi oleh suatu organisasi untuk menghindari sanksi hukum (Burdon dan Sorour, 2020Dalam CS, peraturan umum atau khusus industri mengatur keamanan informasi, pemberitahuan dan pelaporan pelanggaran keamanan (misalnya, Peraturan Perlindungan Data Umum Uni Eropa [GDPR]; Skema Pemberitahuan Pelanggaran Data di Australia; Undang-Undang Sarbanes-Oxley [SOX]; kerangka kerja pelaporan manajemen risiko CS AICPA, 2017;Laporan SEC tahun 2011/2018panduan pengungkapan risiko keamanan siber). Sumber tekanan paksaan lainnya adalah persyaratan industri, vendor, dan pelanggan, seperti mewajibkan adopsi sistem Pertukaran Data Elektronik (EDI).Wallace dkk., 2011), PII (Informasi Identifikasi Pribadi) atau Standar Keamanan Data Industri Kartu Pembayaran (PCI-DSS) (Malhotra, 2018).

Bagaimana organisasi mengkonfigurasi tata kelola CS mereka tidak diatur. Pengecualiannya adalah regulasi kehati-hatian di bidang perbankan. Misalnya, Direktif Uni Eropa 2013/36/EU dan pedoman tahun 2019 untuk teknologi informasi dan komunikasi (TIK) dan manajemen risiko keamanan mensyaratkan independensi fungsi kontrol keamanan informasi (lini kedua) melalui

pemisahan dari proses operasional dan jalur pelaporan langsungnya ke Dewan Direksi. Regulasi yang agak serupa ada dalam konteks Australia melalui Standar Prudential Otoritas Regulasi Prudential Australia CPS 234 Keamanan Informasi. Standar audit internal dengan status 'kekuatan hukum' juga mewajibkan independensi auditor internal (IIA, 2013Namun, karena pelanggaran data dapat melibatkan sanksi yang signifikan[3]Dan tanggung jawab fidusia anggota dewan, organisasi dapat mengadopsi struktur dan proses yang disajikan sebagai praktik terbaik oleh asosiasi profesional untuk menunjukkan bahwa tata kelola siber dan manajemen risiko mereka dilakukan dengan kewajiban kehati-hatian yang diperlukan.

Meskipun regulasi semakin diperketat, kami berpendapat bahwa tekanan paksaan merupakan hal minimal di sebagian besar industri. Di industri perbankan, di sisi lain, penerapan 5 LoA diwajibkan dan memberikan izin untuk beroperasi. Dalam kasus seperti itu, tekanan paksaan memaksa organisasi untuk terlihat jelas dalam mengadopsi model 5 LoA. Namun, bahkan regulasi kehati-hatian pun memungkinkan diskresi manajerial dan menuntut struktur yang proporsional dengan eksposur, kompleksitas, dan sumber daya organisasi; yaitu, mengakomodasi efisiensi konfigurasi tata kelola. Di industri yang tidak diatur, motif efisiensi dan efektivitas cenderung lebih dominan dan mengarah pada struktur tata kelola CS yang lebih sederhana yang sesuai dengan struktur organisasi dan memastikan kelincahan. Struktur tersebut mungkin memungkinkan peran untuk digabungkan atau bahkan tidak ada sama sekali. Dalam kasus ini, organisasi tidak menghadapi tekanan yang sama untuk terlihat mengadopsi model 5 LoA.

*Normatif*Proses-proses tersebut terkait dengan profesionalisasi, yang mendefinisikan metode kerja dalam profesi tertentu (DiMaggio dan Powell, 1983). Kekuatan normatif muncul melalui pendidikan formal, sertifikasi profesional dan pelatihan berkelanjutan, serta keanggotaan jaringan profesional (Vuko dkk., 2021) dan kepatuhan terhadap standar profesional[4]Asosiasi profesional telah secara intensif mempromosikan 5 LoA, dengan IIA dan ISACA mendidik para profesional manajemen risiko, audit, dan tata kelola TI selama hampir tiga dekade. Sertifikasi dan pelatihan CS memengaruhi opini para profesional mengenai pendekatan manajemen risiko mana yang sah.Barton dkk., 2016Jika para profesional bersertifikat memiliki pengaruh dalam merancang struktur tata kelola CS, mereka akan memainkan peran penting dalam mempromosikan adopsi model 5 LoA, atau setidaknya tiga baris pertama jika mereka tidak memiliki pengaruh pada keterlibatan manajemen atau badan pengelola. Pada akhirnya, badan pengelolalah yang memutuskan struktur tata kelola. Adopsi 5 LoA hanya dapat dikaitkan dengan kekuatan normatif jika para manajer eksekutif dan direktur sendiri mengetahuinya, dan agar hal ini terjadi, mereka membutuhkan keahlian dan pelatihan formal yang signifikan.

Akhirnya,*mimetik*Proses terjadi ketika organisasi berupaya meniru organisasi serupa yang diyakini sukses dan/atau sah (Ogbanufe dkk., 2021 Kekuatan mimetik sangat kuat ketika suatu organisasi menghadapi ketidakpastian yang tinggi, penyebab yang ambigu, dan solusi yang tidak jelas. DiMaggio dan Powell, 1983Hal ini muncul melalui para profesional yang berinteraksi antar organisasi; para direktur yang bertugas di berbagai dewan; dan transfer pengetahuan melalui membaca artikel profesional yang sama atau mempekerjakan pakar industri yang sama.Lin dkk., 2020Namun, kekuatan mimetik mungkin tidak mendorong adopsi 5 LoA, melainkan struktur yang lebih sederhana. Motif efisiensi dan legitimasi berinteraksi kuat dalam keputusan tersebut. Kami berpendapat bahwa ketika struktur tata kelola organisasi lain ditiru tetapi diadaptasi untuk mempertimbangkan ukuran, kompleksitas, persaingan industri, dan paparan risiko organisasi, motif legitimasi mengakomodasi motif efisiensi/efektivitas. Misalnya, organisasi besar dan kompleks dapat mengadopsi 5 LoA karena efisien karena cukup banyak ahli yang dipekerjakan dalam peran yang terpisah dengan baik. Bagi organisasi yang lebih kecil, kurang terpapar, dan kurang kompleks, struktur seperti itu mungkin dianggap terlalu mahal, kaku, dan tidak sesuai dengan konteks mereka.

Diskusi ini memberikan dasar untuk mengkonseptualisasikan pilihan konfigurasi tata kelola (Gambar 1). Hal ini mengidentifikasi struktur normatif yang akan dibandingkan dengan pilihan struktur dan mekanisme relasional aktual organisasi (De Haes dan Van Grembergen, 2009 Kerangka konseptual ini menjadi dasar pendekatan dan metode penelitian yang diadopsi dalam studi ini.

3. Metode

3.1. Pendekatan penelitian lapangan

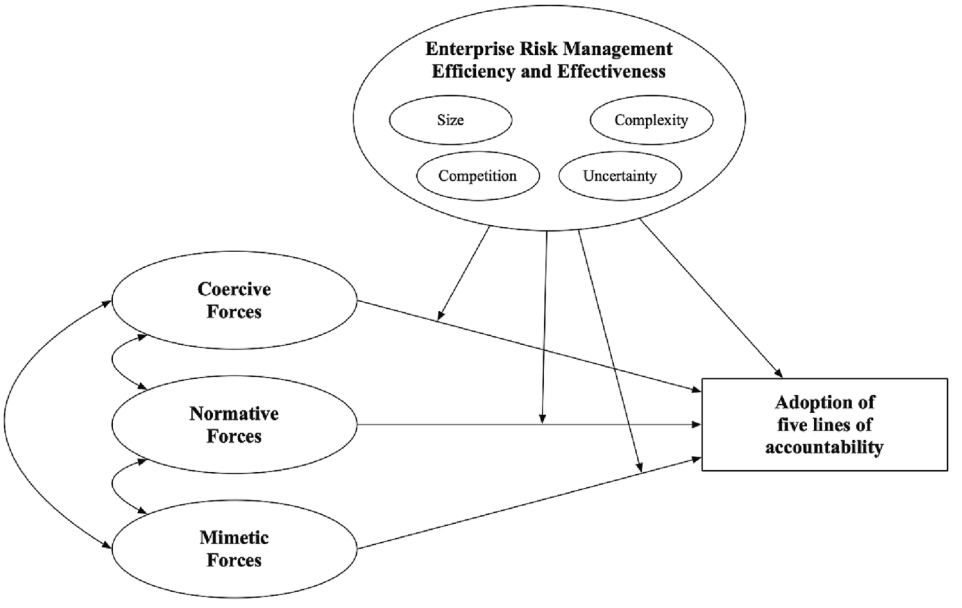
Sejalan dengan tujuan penelitian kami, pendekatan konstruktivis diadopsi untuk memberikan pemahaman tentang konfigurasi tata kelola siber (Lincoln dkk., 2011Pendekatan konstruktivis memberikan pengamatan autentik terhadap praktik aktual sebagaimana yang dibangun oleh aktor sosial yang terlibat (Constantino, 2008; Lincoln dkk., 2011), dan lebih berfokus pada pengembangan pemahaman daripada menjelaskan fenomena tersebut. Kami melakukan riset lapangan dengan lima organisasi di berbagai sektor, semuanya memiliki paparan risiko CS yang tinggi, tetapi dalam konteks yang berbeda.

Kami menargetkan 3–5 individu senior kunci di setiap organisasi yang bertanggung jawab untuk menyampaikan, mengelola risiko, dan memastikan risiko CS sebagai bagian dari lini pertama (misalnya, operasi keamanan), lini kedua (misalnya, pemantauan kepatuhan/manajemen risiko), dan lini ketiga (misalnya, audit internal) serta manajer eksekutif dan anggota Dewan sebagai lini keempat dan kelima. Untuk merekrut responden kami, kami mengadopsi teknik pengambilan sampel bertujuan (Patton, 2014) dan mengidentifikasi kandidat yang sesuai melalui hubungan strategis antara calon responden organisasi, lembaga penelitian penulis, dan penulis itu sendiri.

Wawancara didasarkan pada protokol wawancara semi-terstruktur (Marshall dan Rossman, 2011) yang mengikuti tema umum, tetapi disesuaikan dengan posisi masing-masing responden. Setiap wawancara dijadwalkan sekitar 60 menit. Wawancara direkam dan ditranskripsikan dengan izin dari masing-masing responden, atau catatan lapangan terperinci diambil jika izin tidak diberikan. Semua wawancara bersifat sukarela, dan transkripsinya dianonimkan dan tidak dapat diidentifikasi. Protokol wawancara disediakan dalam Lampiran untuk studi ini.

[3]GDPR, misalnya, menetapkan denda maksimum sebesar EUR 20 juta atau 4% dari omset global untuk pelanggaran data.

[4]Tujuan Pengendalian untuk Teknologi Informasi dan Teknologi Terkait [COBIT oleh ISACA], standar CS yang dikeluarkan oleh Organisasi Internasional untuk Standardisasi [ISO 27001/2], standar yang dikeluarkan oleh Institut Standar dan Teknologi Nasional AS [NIST, 2018], atau lainnya.



Gambar 1. Kerangka konseptual penerapan lima jalur akuntabilitas.

Penelitian ini telah memperoleh izin etik dari universitas penulisnya.

3.2. Organisasi yang berpartisipasi

Kami menargetkan dan merekrut lima organisasi besar terkemuka untuk berpartisipasi dalam studi ini. Empat peserta adalah organisasi Australia di berbagai industri, sedangkan peserta kelima adalah bank sistemik di Zona Euro.Tabel 1memberikan informasi latar belakang untuk organisasi-organisasi ini.

Bank tersebut direkrut untuk mewakili konteks regulasi manajemen risiko yang ketat, karena tunduk pada regulasi EBA, regulasi kehati-hatian Bank Sentral Eropa, dan GDPR. Lampiran A menjabarkan fungsi, peran, dan latar belakang responden.

3.3. Proses pengkodean

Setiap transkrip wawancara awalnya dikodekan sesuai dengan kerangka konseptual kami (Gambar 1) untuk mencerminkan motif efisiensi/efektivitas dan kekuatan teori institusional. Oleh karena itu, kami melakukan pengkodean untuk mengidentifikasi faktor-faktor efisiensi (ukuran, kompleksitas, paparan risiko, dan persaingan) serta tekanan koersif, mimetik, dan normatif dan efektivitas yang dibahas oleh para peserta.

Sebagai penelitian eksploratif, kami juga menggunakan pengkodean terbuka (yaitu, tidak melakukan pengkodean berdasarkan kerangka konseptual) untuk mengidentifikasi pernyataan tambahan.

Tabel 1
Deskripsi singkat organisasi yang berpartisipasi.

	Organisasi A	**B**	**C**	**D**	**E**
KONTEKS ORGANISASI					
Sektor Industri	Universitas (Tersier Pendidikan)	Kesehatan (Pemerintah)	Pengecer Konglomerat (Pengecer)	Penyedia Layanan TI Korporat (Cabang Australia)	Bank (Eropa)
Pendapatan Tahunan	AUD 2,1 miliar	AUD 21,8 miliar	AUD 2,8 miliar	AUD 1 miliar	EUR 865 juta (AUD) 1,4 miliar)
Total aset	AUD 4,6 miliar	AUD 4,5 miliar	AUD 2,9 miliar	Tidak tersedia	EUR 19,5 miliar (AUD 31,5 miliar)
Jumlah karyawan (Perkiraan)	7.000	79.200	13.000	2.100	8.800
RESPONDEN¼24					
Baris ke-1 dan ke-2	2	2	2	2	2
Baris ke-3	1	1	1		1
Manajemen eksekutif	2	1	2	1	1
Anggota Dewan	1	1			1
JUMLAH TOTAL:	6	5	5	3	5

dari minat penelitian dan membangun struktur data untuk mengkonseptualisasikan konfigurasi tata kelola CS. Kami mulai dengan pengkodean awal pernyataan yang dibuat dalam masing-masing dari 24 wawancara. Kemudian kami mengadopsi pendekatanGioia dkk. (2013)Untuk membangun struktur data yang ketat yang menyajikan konsep tingkat pertama, konsep tingkat kedua, dan dimensi agregat. Secara keseluruhan, kami mengidentifikasi 57 kode konsep tingkat pertama dan 19 konsep tingkat kedua yang diagregasikan menjadi enam dimensi. Struktur data yang dibangun dari wawancara disajikan dalam Lampiran B. Pengkodean mengidentifikasi mekanisme tata kelola yang ada dan mekanisme yang dibahas dalam 5 LoA dan area operasional relevan lainnya. Secara keseluruhan, struktur data yang muncul mendukung dan menginformasikan temuan kami.

4. Temuan

4.1. Apa saja konfigurasi tata kelola CS terkait dengan lima jalur akuntabilitas?

4.1.1. Struktur tata kelola Peran

lini pertama dan kedua

Dalam organisasi peserta, peran lini pertama dan kedua umumnya digabungkan, atau bekerja sama secara erat. Seringkali kedua peran ini bersifat hierarkis, tetapi peran yang bertanggung jawab untuk memantau kontrol dan menetapkan kebijakan siber mungkin mencakup beberapa fungsi lini pertama.

Perbedaan antara peran lini pertama dan lini kedua seringkali tidak jelas. Paling sering, kami menemukan lini pertama mencakup unit bisnis seperti Pusat Operasi Keamanan (SOC) dan aktivitas seperti deteksi dan respons insiden, manajemen kerentanan, manajemen vendor, pengujian penetrasi, pemilihan dan implementasi kontrol keamanan, operasi pengembangan (DevOps), arsitektur keamanan, otomatisasi sistem, pengujian produk keamanan, pengembangan proses seputar topik dan area spesifik (misalnya, phishing), dll. Lini kedua mencakup fungsi kepatuhan keamanan siber dan informasi, manajemen risiko siber, pemantauan kontrol keamanan siber, dan pengembangan kebijakan, protokol, dan prosedur. Dari perspektif manajemen risiko, responden menyoroti bahwa fungsi utama lini kedua adalah untuk memahami tingkat paparan organisasi terhadap risiko siber, yang kemudian dilaporkan oleh eksekutif puncak di bidang keamanan siber (misalnya, CIO, CISO) kepada Dewan Direksi dengan meringkas ancaman utama secara ringkas.

Lini kedua juga membuat keputusan defensif penting terkait jejak digital organisasi dan, secara umum, tentang bagaimana mengubah daya tarik sistem organisasi terhadap penyerang eksternal. Peran lini kedua mungkin juga bertanggung jawab atas rencana kesinambungan bisnis dan perencanaan bencana, atau manajer CS mungkin menjadi bagian dari tim, yang dikelola oleh fungsi berbeda dalam organisasi. Di organisasi perawatan kesehatan (B) dan Universitas (A), fungsi ini berada di dalam area manajemen risiko dan bukan di dalam departemen CS atau TI karena mereka menangani risiko yang lebih luas.

Tanggung jawab penting lainnya yang melibatkan kedua lini tersebut adalah menentukan Indikator Kinerja Utama (KPI) yang tepat untuk pelaporan kepada manajemen eksekutif dan Dewan Direksi. Secara umum, meskipun dengan beberapa pengecualian, organisasi yang berpartisipasi memiliki tingkat kematangan yang rendah dalam menetapkan metrik tersebut. Dalam kebanyakan kasus, Dasbor pelaporan Keamanan Siber dianggap sebagai pekerjaan yang sedang berlangsung. Hal ini menunjukkan meningkatnya sensitivitas terhadap jenis instrumen manajemen risiko siber ini. Indikasi frekuensi pelaporan tersebut berguna dalam menentukan pentingnya masalah terkait siber bagi para pemimpin organisasi tingkat atas.

Struktur akuntabilitas bergantung pada*ukuran*Dari organisasi: semakin besar dan kompleks organisasi, semakin banyak unit di setiap level yang dikonfigurasi secara hierarkis atau horizontal. Pemisahan paling jelas antara lini pertama dan kedua diamati di bank (Organisasi E) dan Universitas (Organisasi A). Paparan terhadap ancaman siber (ketidakpastian lingkungan) juga disebutkan sebagai faktor dalam jumlah sumber daya yang siap diinvestasikan oleh suatu organisasi dalam manajemen risiko CS ("*Sesuai kebutuhan*", C3, manajemen eksekutif). Seringkali, peran lini kedua mewakili tim yang relatif kecil dan terpusat. Namun, peran tersebut tetap memanfaatkan sub-unit di dalam unit bisnis yang berbeda, termasuk, misalnya, petugas keamanan regional, titik kontak keamanan, dan tim CISO lokal.

Beberapa organisasi yang berpartisipasi memiliki struktur matriks yang kompleks karena ukuran dan segmentasi geografisnya. Mereka memiliki satu CISO di tingkat regional dan satu CISO di tingkat layanan (Penyedia layanan TI Korporat, D), atau seorang CISO Grup yang mengkoordinasikan aktivitas seorang CISO di bank induk dan di setiap anak perusahaan (Bank, E). Karena konfigurasi tata kelola diatur dalam bentuk matriks, sebagian besar posisi memiliki dua jalur pelaporan. Dalam organisasi Konglomerat Ritel (C), fungsi manajemen risiko CS dari jalur pertama dan kedua dibagi menjadi dua unit yang disusun secara horizontal: 'Keamanan dan Operasi' dan 'Keselamatan dan Keamanan', yang berbagi berbagai tanggung jawab dalam CS.

Pada prinsipnya, peran lini kedua juga mencakup fungsi manajemen risiko umum. Fungsi CS dan manajemen risiko berkolaborasi dalam berbagai tingkat di berbagai organisasi yang berpartisipasi. Misalnya, di Universitas (A), kami mengamati kesadaran CIO tentang kebijakan ERM dan ambang batas kritis untuk tingkat risiko dalam matriks pengendalian risiko, strategi risiko keseluruhan, dan selera risiko. Meskipun kedua fungsi tersebut beroperasi secara terpisah setiap hari, keduanya dikelola bersama oleh Chief Operating Officer (COO) yang menjadi atasan keduanya. Karena pentingnya CS dan tingkat keahlian CIO, ia juga melapor langsung kepada Komite Risiko dan Audit Senat Universitas.

Salah satu aspek manajemen risiko CS adalah ketergantungan intensif pada penyedia eksternal seperti pusat operasi keamanan, vendor perangkat lunak yang menyediakan informasi tentang kerentanan perangkat lunak dan patch yang muncul, serta mitra intelijen yang memberikan pandangan terkini tentang paparan risiko siber dan tolok ukur eksternal. Keterlibatan penyedia eksternal dikelola oleh berbagai lini tergantung pada layanan yang diberikan.

Baris ketiga–Fungsi audit internal

Sebagian besar responden, selain auditor internal itu sendiri, melihat fungsi audit internal tidak terlibat secara kritis dalam manajemen risiko CS sampai-sampai beberapa organisasi tidak merasa perlu bagi kami untuk mewawancarai auditor internal. Pengecualiannya adalah Bank (E), di mana fungsi audit TI dengan sepuluh karyawannya sangat dihargai, dan setiap auditor TI memiliki dua sertifikasi siber.

Namun demikian, komentar yang berulang kali muncul dari organisasi lain adalah bahwa audit internal jarang memiliki kompetensi dan keahlian khusus untuk mengaudit CS (Crew Security) dan malah mencakup lingkup TI dan sistem informasi yang lebih luas.

Sejalan dengan hal ini, outsourcing audit CS muncul berulang kali dalam data kami kecuali untuk Bank (E). Akibatnya, peran utama auditor internal adalah mengelola hubungan dengan penyedia layanan audit eksternal, memungkinkan akses ke sumber informasi yang dibutuhkan, dan memastikan layanan diberikan sesuai standar yang diharapkan. Namun, berbeda dengan bagaimana responden di bidang lain memandang auditor internal, seorang auditor internal mencatat:

> *"Secara internal, kami memiliki cukup banyak pengalaman dalam tinjauan keamanan siber, tetapi kami memilih untuk melakukan co-sourcing.–karena keterbatasan sumber daya dalam hal jumlah, keterbatasan kemampuan, dan juga alasan politik....]Yang masih kurang dari kita adalah kemampuan untuk melakukan benchmarking terhadap organisasi lain. Untuk melakukan penilaian kematangan. Empat perusahaan akuntansi terbesar (Big Four) melakukan banyak audit siber dan memiliki tolok ukur."*(A6, auditor TI).

Beberapa responden merinci tugas-tugas tipikal yang akan dilakukan oleh tim audit internal mereka. Sebagian besar tugas berkisar pada penilaian risiko utama bagi organisasi (baik dengan melakukan latihan penilaian risiko internal atau dengan menggunakan kembali informasi yang dikumpulkan di berbagai unit organisasi lainnya), menentukan apakah pengendalian risiko yang tepat telah diterapkan, dan menilai efektivitas pengendalian yang ada. Auditor TI bank tersebut menjelaskan:

> *"Kami lebih memilih fokus pada penilaian risiko dan tata kelola daripada pada kontrol teknis. Di masa sekarang, tidak mungkin untuk memeriksa setiap kontrol. Jauh lebih penting bahwa proses dirancang dengan baik, diotomatisasi, dan benar-benar diimplementasikan. Jika kita hanya fokus pada satu kontrol, kita tidak akan mencapai hasil yang maksimal."*(E1).

Salah satu topik yang muncul terkait audit internal adalah meningkatnya 'kebutuhan' akan data yang seharusnya dimiliki oleh fungsi tersebut. Salah satu responden menjelaskan bahwa kemampuan analitik data semakin banyak diterapkan di organisasi mereka untuk menyediakan tim audit internal dengan data yang lebih andal dan 'langsung' mengenai risiko yang diaudit dan kontrol terkait. Sekali lagi, kolaborasi erat dengan tim keamanan siber (misalnya, lini pertama) atau fungsi kepatuhan dan tata kelola (misalnya, CISO) digambarkan sebagai hal yang sangat penting untuk keberhasilan audit.

Baris keempat–manajemen eksekutif

Di berbagai organisasi, peran lini kedua melapor kepada berbagai manajer eksekutif (yaitu, kepada COO, Kepala Keuangan/Risiko/Hukum/Kepatuhan, atau bahkan langsung kepada Dewan Direksi). Selain itu, berbagai peran lini kedua sering melapor kepada manajer senior yang berbeda dalam organisasi yang sama. Pelaporan terdesentralisasi dari ketiga lini tersebut diintegrasikan kembali pada tingkat komite khusus yang melibatkan berbagai manajer eksekutif, termasuk beberapa atau semua dari berikut ini: Kepala Eksekutif, Kepala Keuangan, Kepala Kepatuhan dan Hukum, Kepala SDM, COO, CIO. Komite-komite tersebut memiliki berbagai nama dan tidak hanya menangani keamanan siber, tetapi juga audit umum, kepatuhan, dan/atau manajemen risiko. Komite-komite tersebut bertemu setiap bulan, dua bulanan, atau triwulanan untuk membahas paparan risiko organisasi, perkembangan di industri, dan kinerja organisasi dalam manajemen risiko siber. Karena perkembangan yang pesat, komite-komite tersebut secara aktif terlibat dalam mengawasi pengembangan kebijakan atau peningkatan metrik risiko. Namun, laporan keamanan siber pada tingkat ini diringkas menjadi metrik risiko utama yang tampaknya tidak terintegrasi dengan manajemen risiko perusahaan (ERM).

Oleh karena itu, tidak mengherankan jika para manajer eksekutif dan manajer keamanan dari lini pertama dan kedua dalam organisasi yang sama memiliki persepsi yang berbeda tentang kematangan manajemen risiko siber. Di semua organisasi, pelaporan manajemen risiko CS didorong dari bawah ke atas:

> *"Anda harus memahami audiens Anda untuk memastikan pesan yang Anda sampaikan tepat. Saya harus menyajikan konten yang cukup kepada dewan direksi dan audiens eksekutif, tetapi disesuaikan dengan apa yang menurut saya relevan dan apa yang menurut saya dapat Anda simpulkan secara wajar dari berbagai poin yang telah saya berikan."..."Sebagian besar eksekutif menyadari pentingnya keamanan siber, tetapi kurang memiliki pemahaman yang mendalam. Oleh karena itu, mereka sangat bergantung pada para ahli di bidang tersebut."*(D3, CISO).

Sebaliknya, nada dari pimpinan tertinggi lebih terartikulasi di Bank, di mana Ketua Komite Risiko Bank (BoD) dan CRO Bank menyadari bahwa laporan yang penuh dengan detail teknis tidak sesuai dengan tujuan. Manajemen eksekutif telah menugaskan CISO baru dan CISO Grup untuk mengembangkan laporan yang lebih bermakna yang membahas risiko siber bank melalui KPI yang nyata dan menghubungkannya dengan strategi dan proses CS.

Baris kelima–dewan direksi

Baris terakhir adalah Dewan Direksi yang seharusnya memberikan kepemimpinan dan pengawasan dalam manajemen risiko CS. Kami mewawancarai ketua dari dua komite Audit dan Risiko – satu di Universitas (A), dan satu lagi di Bank (E). Di Universitas (A), kutipan berikut menggambarkan bagaimana ketua tersebut sebenarnya melihat peran mereka:

> *"Yang diharapkan dari kita adalah memastikan bahwa kita memahami risikonya dan bahwa kita memiliki orang-orang yang tepat di dalam tim."…. "Dewan Direksi tidak bertanggung jawab atas masalah ERM; Dewan Direksi bertanggung jawab untuk memastikan bahwa manajemen memiliki kerangka kerja ERM yang tepat. Dewan Direksi bertanggung jawab untuk memastikan bahwa mereka memiliki sumber daya yang cukup di bidang teknologi ini untuk melindungi diri mereka dari serangan siber.*(A2, Ketua Komite Audit).

Meskipun CIO secara langsung melapor kepada komite Audit dan Risiko mengenai CS empat kali per tahun, Senat Universitas sendiri tidak membahas CS. Para responden dari organisasi B, C, dan D menyatakan bahwa Dewan Direksi mereka dilaporkan oleh ketua komite risiko manajemen eksekutif, langsung oleh CIO, oleh auditor internal, dan/atau oleh penyedia jaminan independen. Berbeda dengan area pengawasan yang lebih mapan (misalnya, kinerja keuangan) di mana direktur non-eksekutif memiliki kompetensi dan pemahaman yang mapan, di bidang CS mereka tidak*bukan*Menetapkan ekspektasi dan memiliki sedikit keterlibatan dalam penyusunan strategi, mendefinisikan selera risiko, dan/atau memengaruhi KPI mana yang dilaporkan. Sebagian besar anggota Komite Risiko dan Audit Dewan Direksi adalah akuntan dan profesional hukum yang biasanya memiliki sedikit atau tidak sama sekali pengetahuan tentang CS (Corporate Social Responsibility). Hal ini menciptakan tantangan lebih lanjut mengenai bagaimana dan apa yang harus dilaporkan kepada mereka. Meskipun manajer eksekutif (lini ke-4) berkontribusi pada pengembangan laporan CS yang bermakna, kami menemukan bahwa Dewan Direksi tidak melakukannya.

Ketidaknyamanan dengan laporan tersebut, baik karena kurangnya pemahaman atau karena mereka perlu membandingkan KPI internal untuk lebih memahami ancaman CS, mengakibatkan seringnya kebutuhan untuk menyewa konsultan eksternal untuk memberikan nasihat dan jaminan tersebut.

Namun, bank tersebut telah merekrut seorang Chief Data Science Officer dari bank lain untuk bergabung dengan Dewan Direksi, dan ketua komite Risiko juga berasal dari latar belakang teknis. Lebih jauh lagi, ketua tersebut telah menyelesaikan pelatihan Ilmu Komputer di sebuah universitas ternama. Ia mencatat:

> *"Risiko siber adalah risiko yang paling mendesak dan paling signifikan saat ini, selain risiko kredit dan likuiditas, ini sebenarnya adalah risiko utama yang kita hadapi."* (E2).

Pelaporan mengenai masalah manajemen risiko CS kepada Dewan Direksi Bank sangat luas (tetapi agak tersebar) melalui tiga komite: CISO melapor kepada komite Risiko serta komite Operasi dan TI, dan auditor internal melapor kepada Komite Audit.

4.1.2. Mekanisme relasional tata kelola

Para responden kami sering membahas kolaborasi intensif antara lini pertama dan kedua, khususnya antara para profesional keamanan dan CIO/CISO, tetapi tidak begitu banyak dengan auditor internal sebagai lini ketiga. Tampaknya independensi auditor internal mengorbankan relevansi mereka bagi manajer lini kedua, manajer eksekutif, dan dewan direksi. Sementara itu, auditor internal mencatat bahwa manajemen risiko siber belum cukup matang. Hal ini mengakibatkan beberapa tugas penting dilakukan dua kali, yaitu secara terpisah, oleh lini kedua dan ketiga:

> *"Idealnya, manajemen risiko akan melakukan penilaian risiko. Tetapi mereka belum mencapai tingkat kematangan itu. Dalam dunia ideal, kita ingin mengandalkan manajemen yang kompeten. Tanpa itu, kita harus melakukan perhitungan risiko sebaik mungkin. Dan penerapan kerangka kerja ERM tidak sempurna (terlalu umum), jadi kita harus mengisi celah-celahnya."* (A6, auditor internal).

Kurangnya kepercayaan dan kerja sama tersebut dapat menyebabkan duplikasi pekerjaan dan kesenjangan antara ketiga lini dan manajer ERM. Persepsi tentang peran auditor internal berbeda di Bank. Kami tidak mengamati adanya kurangnya kepercayaan terhadap kompetensi auditor internal. Dewan Direksi bank dan lini lainnya mengharapkan peran auditor internal lebih berfokus pada... *"lebih menyoroti kekurangan proses daripada menguji kontrol teknis."* (Ketua Komite Risiko, E4). Meskipun secara formal terpisah, tingkat komunikasi informal antar lini meningkat karena para manajer di tiga lini pertama sering bertemu satu sama lain dan memiliki kantor yang berdekatan. Di organisasi layanan kesehatan (B), Wakil Ketua Komite Audit dan Risiko mengatakan bahwa menurut pandangannya *"...Harus ada alur yang sangat kuat dan hubungan kerja yang benar-benar baik antara manajemen risiko dan audit."* (B5).

Mengingat ketidakseimbangan informasi dan kompetensi para manajer CS dibandingkan dengan manajemen eksekutif dan Dewan Direksi, pelaporan manajemen risiko CS di semua institusi didorong dari bawah ke atas. Para responden kami, khususnya CISO/CIO, menunjukkan bahwa mereka menerima sedikit sekali panduan dari atas dan hanya menerima pernyataan persyaratan tingkat tinggi. Mereka juga menyadari ketidakseimbangan pengetahuan tersebut. Seringkali, peran lini kedua mengikuti prinsip 'manajemen berdasarkan pengecualian' dan hanya melaporkan masalah ketika mereka merasa itu tepat agar tidak terlalu sering dan terlalu cepat membuat khawatir dewan direksi.

Disebutkan juga bahwa informasi yang dilaporkan kepada Dewan Direksi jauh lebih sedikit daripada kepada manajemen eksekutif. Akibatnya, manajer eksekutif dan Dewan Direksi menunjukkan ketergantungan yang berlebihan pada manajer CS.

Ketika mencari jaminan independen, Dewan Direksi tampaknya lebih memilih penyedia eksternal, tetapi penyedia layanan ini hanya dipekerjakan setiap beberapa tahun sekali. Kekhawatiran utama Dewan Direksi adalah untuk memahami seberapa matang manajemen risiko CS, apakah tingkat investasi sebanding dengan rekan-rekan mereka, dan apa saja ancaman yang muncul. Informasi yang diberikan oleh auditor internal tentang seberapa baik organisasi mematuhi kebijakan, strategi, kerangka kerja CS, dan seberapa baik manajemen risiko CS selaras dengan ERM (yaitu, pada status quo) tampaknya menjadi perhatian sekunder. Sekali lagi, pengecualiannya adalah Bank (E), yang mempekerjakan konsultan eksternal dalam jumlah terbatas (intelijen ancaman) dan berinvestasi secara signifikan dalam kemampuan internal. Seringnya perubahan posisi pada dua lini pertama agak memperlambat perkembangan mereka.

Ketidaksesuaian antara dua baris pertama dan baris ketiga menyebabkan manajemen risiko siber yang suboptimal. Berbagai penilaian risiko, ambang batas yang berbeda untuk tingkat kritis berbagai risiko, tidak adanya integrasi ke dalam matriks risiko ERM, evaluasi kematangan yang tidak konsisten oleh berbagai pihak, dan pelaporan yang terfragmentasi kepada jajaran atas tampak jelas. Kekuasaan informal yang berasal dari kompetensi dan asimetri informasi yang signifikan pada akhirnya menempatkan ketergantungan yang sangat besar pada satu individu dalam manajemen risiko siber. Kutipan dari Wakil Ketua Komite Audit dan Risiko di organisasi perawatan kesehatan (B) mewakili kepercayaan buta yang tampaknya dimiliki dewan dan eksekutif terhadap CISO mereka:

> *"Saya ingat dia sebagai sosok yang sangat cakap, kompeten, dan tenang. Dia berasal dari latar belakang militer, jadi ketika Anda merasa seperti tembok runtuh di sekitar Anda, dia akan dengan tenang duduk, membicarakan masalah, membahas perawatan, membahas apa yang mereka lakukan, dan langsung bertindak. Dia sangat, sangat bagus dalam posisinya. Dia kemudian direkrut untuk konsultasi dan kemudian dijual kembali kepada kami dengan tarif tinggi."* (B5)

Ditambah dengan kesalahpahaman tentang peran orang lain dan ketidakpercayaan terhadap kompetensi, hubungan informal ini memberikan sudut pandang yang agak berbeda terhadap fungsi struktur formal.

4.1.3. Mendefinisikan jenis penerapan 5 LoA

Pertanyaan penelitian inti kami adalah mengapa penting bagi organisasi untuk mengadopsi 5 LoA. Untuk menjawabnya, pertama-tama kami mendefinisikan apa artinya mengadopsi model 5 LoA dalam mengkonfigurasi tata kelola CS. Kami mengkonseptualisasikan jenis adopsi menurut dua dimensi. Dimensi pertama adalah... *pemisahan jalur*–yaitu, menjaga independensi peran yang bertanggung jawab untuk menetapkan kontrol dari pihak-pihak yang

Memantau mereka. Ada empat aspek yang perlu dipertimbangkan dalam praktiknya. Pemisahan lini dapat dinilai dengan mempertimbangkan sejauh mana pemisahan lini kedua dari lini pertama untuk memastikan pemantauan objektif. Independensi lini ketiga dari dua lini pertama untuk memastikan jaminan independen juga merupakan aspek penting dari penilaian ini. Lebih lanjut, lini kedua dan keempat dapat dipisahkan hingga berbagai tingkat – misalnya, termasuk atau tidak termasuk CIO dalam manajemen eksekutif. Aspek terakhir berkaitan dengan mendefinisikan peran yang jelas terpisah dari manajemen eksekutif untuk Dewan Direksi dalam pengawasan dan pembentukan jalur pelaporan langsung dari lini kedua dan ketiga ke Dewan Direksi (EBA, 2019Dalam praktiknya, pemisahan galur berkisar dari campuran hingga terpisah.

Dimensi kedua adalah*tingkat keterlibatan dalam 5 LoA*Publikasi dan pedoman profesional (COSO, 2017; IIA, 2020) dan penelitian sebelumnya (misalnya,Kappelman dkk., 2017; Kappelman dkk., 2016; Slapničar dkk., 2022; Vincent dkk., 2019; Higgs dkk., 2016Sebagian besar responden setuju bahwa keterlibatan aktor organisasi di semua tingkatan organisasi merupakan elemen penting untuk hasil manajemen risiko keamanan siber yang positif. Kami mendefinisikan keterlibatan sebagai berkisar dari rendah hingga tinggi. Temuan kami menunjukkan bahwa pemisahan lini tidak secara otomatis mengarah pada keterlibatan yang lebih tinggi. Aktor organisasi mungkin terlibat bahkan jika suatu organisasi menggabungkan beberapa lini. Atau, aktor organisasi mungkin tidak terlalu terlibat dalam peran mereka meskipun peran tersebut cukup formal dan terpisah. Misalnya, tidak semua organisasi kami melihat peran auditor internal sebagai hal yang penting dalam manajemen risiko keamanan siber; sebaliknya, mereka mengandalkan konsultan eksternal atau lini kedua untuk jaminan. Kami juga menganggap keterlibatan rendah terjadi ketika peran manajemen eksekutif dan anggota Dewan terbatas hanya pada mencatat laporan yang diterima – yaitu, mereka tidak menantang laporan tersebut, tidak berpartisipasi dalam pembentukan strategi risiko siber, atau tidak secara komprehensif mengawasi tindakan manajemen.

Temuan deskriptif kami menunjukkan bahwa kedua dimensi tersebut tidak berhubungan secara kausal. Artinya, formalisasi garis-garis tersebut belum tentu memicu keterlibatan yang lebih besar dari peserta organisasi. Kombinasi dari kedua dimensi tersebut mengidentifikasi berbagai tipe.[5]dari adopsi 5 LoA termasuk “tidak ada adopsi”, “adopsi yang tampak”, “adopsi implisit”, dan “adopsi eksplisit”. Sejalan dengan penelitian lain (Eulerich, 2021), “tidak ada adopsi” terjadi ketika organisasi belum mendefinisikan garis-garis tersebut atau memilih untuk menggabungkannya, dan individu yang menjabat di sebagian besar garis tersebut memiliki sedikit keterlibatan dengan persyaratan peran mereka. Meskipun tidak ada peserta organisasi dalam penelitian kami yang berada di kuadran 'tidak ada adopsi' pada saat penelitian, peserta menyebutkan pendekatan mereka sebelumnya terhadap tata kelola CS sebagai kurang matang atau tidak ada. Atas dasar ini, organisasi yang diklasifikasikan berada di kuadran 'tidak ada adopsi' mungkin memiliki fungsi keamanan siber, tetapi tata kelola keamanan siber mereka bersifat reaktif atau kurang memiliki desain yang terarah.

Jika sebaliknya semua jalur secara formal ditetapkan dan dipisahkan tetapi individu-individu dalam peran tersebut menunjukkan tingkat keterlibatan yang rendah, maka ini menunjukkan '*adopsi yang tampak nyata*dari 5 LoA. Adopsi yang tampak terjadi ketika, secara lahiriah, 5 LoA ada di tempatnya dan dipisahkan dengan jelas, tetapi adopsi tersebut sebenarnya dangkal. Artinya, garis wewenang mudah dikenali, tetapi tingkat keterlibatan dalam peran-peran tersebut sebenarnya tidak tinggi.

Kontradiksi terhadap adopsi yang tampak jelas adalah '*adopsi implisit*'Jenis adopsi ini mengakui fleksibilitas dan integrasi ('perpaduan') lini yang dimungkinkan dalam mengadopsi 5 LoA (Eulerich, 2021'Adopsi implisit' adalah ketika suatu organisasi memadukan beberapa dari 5 Garis Otoritas (LoA) daripada memisahkannya, dan di mana individu-individu dalam peran 5 LoA terlibat secara efektif dengan 5 LoA. Berbeda dengan adopsi yang tampak, dalam adopsi implisit garis otoritas tidak begitu mudah dibedakan, tetapi di balik permukaan terdapat keterlibatan aktif dalam peran yang ditetapkan dalam 5 LoA. Jenis adopsi terakhir dari 5 LoA adalah '*adopsi eksplisit',*Hal ini muncul ketika garis-garis tersebut didefinisikan dan dipisahkan dengan jelas, dan ketika semua individu yang bertanggung jawab terlibat dan menjalankan tanggung jawab serta akuntabilitas mereka seperti yang dijelaskan dalam latar belakang teoritis kita. Adopsi eksplisit muncul ketika ada adopsi yang jelas dan aktif dari 5 LoA oleh organisasi.

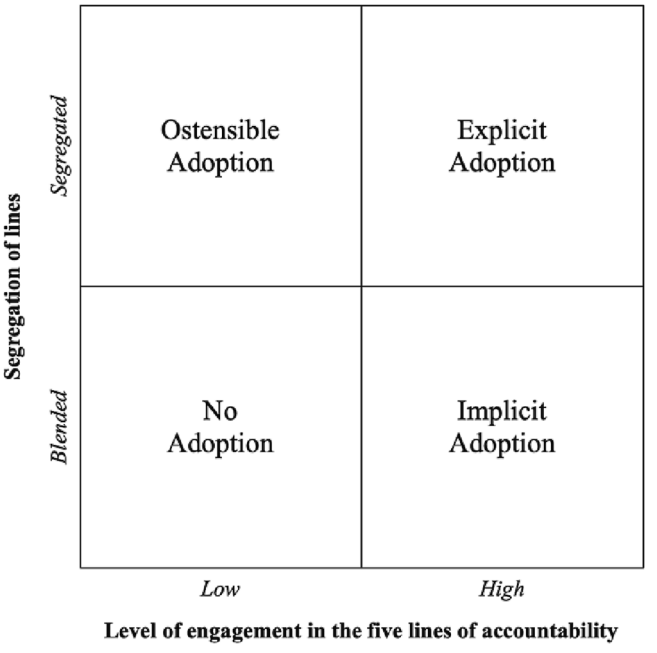
Baik adopsi yang tampak maupun adopsi eksplisit mengadopsi konfigurasi tata kelola CS yang jelas sejalan dengan 5 Prinsip Aksi (5 LoA). Bagi pemangku kepentingan eksternal, jelas bahwa 5 LoA diadopsi dalam kedua kasus tersebut. Untuk adopsi implisit, tidak begitu jelas bagi pemangku kepentingan eksternal bahwa 5 LoA diadopsi, tetapi secara internal jelas bahwa peran-peran tersebut secara aktif dijalankan. Dalam hal ini, keterlibatan yang lebih tinggi melalui peran yang lebih terpadu daripada peran yang terpisah dianggap lebih tepat karena pertimbangan efisiensi dan efektivitas. Gambar 2Berikut ini menggambarkan berbagai jenis penerapan 5 LoA untuk menjelaskan konfigurasi tata kelola CS sesuai dengan pemisahan jalur dan tingkat keterlibatan dalam jalur akuntabilitas.

Pada bagian selanjutnya, kami akan membahas mengapa beberapa organisasi secara aktif mengadopsi 5 LoA ('adopsi implisit' atau 'adopsi eksplisit') dan yang lainnya tidak mengadopsi 5 LoA atau hanya mengadopsinya secara formal saja ('adopsi semu'). Dengan kata lain, kami menjawab pertanyaan 'mengapa penting apakah model 5 LoA diadopsi?' Model kami memberikan dasar untuk mempertimbangkan bagaimana kekuatan institusional seimbang dengan motif efisiensi dan efektivitas dalam konfigurasi 5 LoA.

4.2. Mengapa penerapan lima jalur akuntabilitas itu penting?

Temuan kami menunjukkan bahwa dalam pengambilan keputusan terkait konfigurasi tata kelola siber, organisasi berupaya mencapai dua tujuan: (i) mematuhi praktik terbaik, dan (ii) mengurangi dampak siber secara efisien. Dalam menghadapi ketidakpastian, di mana pendekatan organisasi yang optimal dan paling efektif belum diketahui, salah satu alasan utama suatu organisasi mengadopsi pendekatan tertentu terhadap tata kelola keamanan siber adalah legitimasi. Artinya, jika praktik tata kelola tidak sah, hal itu sendiri dapat menciptakan risiko siber – risiko litigasi dan reputasi yang menunjukkan bahwa organisasi belum mengelola risiko siber dengan tepat. Dengan meniru model peran yang terkemuka, organisasi tidak hanya mengklaim legitimasi, tetapi juga belajar lebih cepat karena ada templat yang sudah ada untuk diikuti. Di bawah ini kami menjelaskan bagaimana organisasi secara sadar menyeimbangkan faktor efisiensi dan legitimasi.

[5]Kami menyebutnya jenis adopsi, bukan tingkat adopsi, untuk menunjukkan bahwa jenis adopsi tersebut tidak meningkat secara monoton.



Gambar 2. Jenis-jenis penerapan lima jalur akuntabilitas dalam konfigurasi tata kelola keamanan siber.

4.2.1. Meniru orang lain dengan motif legitimasi dan efisiensi/efektivitas

Di antara tekanan institusional, kami mengamati bahwa tekanan mimetik cukup penting dan terwujud melalui berbagai saluran. Kekuatan mimetik tampak dari pemasok dalam rantai pasokan, peserta industri lainnya, konsultan, peserta industri lainnya, anggota dewan, dan asosiasi industri. Ini termasuk, misalnya, vendor yang menyediakan patch perangkat lunak atau mitra intelijen yang memberikan masukan penting dalam penilaian risiko. Berbeda dengan pengelolaan jenis risiko lainnya (misalnya, risiko kredit, risiko pasar), dalam pengelolaan risiko siber, penyedia eksternal biasanya menyediakan layanan yang signifikan. Konfigurasi ini berlaku terlepas dari seberapa besar dan kompleks suatu organisasi, atau seberapa kompeten para profesional di tiga lini pertahanan tersebut. Kebutuhan untuk membandingkan kinerja dengan peserta industri lainnya diberikan sebagai alasan bagi organisasi untuk meniru pihak lain di industri mereka, seperti yang disebutkan dalam kutipan berikut:

> *"Kami mempekerjakan konsultan eksternal. Sangat sulit untuk membandingkan kinerja dengan industri karena orang-orang tidak berbagi data. Kami mengumpulkan dan melaporkan banyak informasi tentang serangan di industri ini, dan kami secara teratur meluncurkan materi edukasi. Ketika terjadi serangan di industri ini, kami bertanya pada diri sendiri, 'Bagaimana hal itu berlaku bagi kami?'"*(C2, manajer risiko).

Namun, meniru dan membandingkan dengan pihak lain terutama merujuk pada proses dan kontrol lini pertama dan kedua tanpa banyak mempertimbangkan pemisahan lini-lini tersebut. Penekanannya adalah pada pelaksanaan peran daripada meniru lini yang terpisah. Organisasi paling memperhatikan pelaksanaan peran teknis mereka secara efektif, dan dengan itu mereka juga berarti kemungkinan untuk melakukan benchmarking.

Di sisi lain, konsultan tata kelola eksternal mempromosikan model 5 LoA dan tampaknya memiliki pengaruh penting pada konfigurasi tata kelola yang diadopsi, terutama dalam kaitannya dengan penilaian mereka terhadap kematangan:

> *"Kami pernah diaudit oleh [firma akuntansi besar], atau lebih tepatnya, diaudit sekaligus memberikan rekomendasi tentang bagaimana struktur organisasi kami seharusnya. Dan mereka menyinggung hal itu terkait dengan tiga lapisan pertahanan."*(C4, Keamanan dan Operasi).

Dalam industri perbankan, keinginan untuk meniru bank lain karena alasan legitimasi serta alasan efisiensi dan efektivitas sebagian besar saling tumpang tindih. Berbagi informasi antar pesaing tentang praktik keamanan siber tampaknya jauh lebih umum daripada di industri non-regulasi lainnya. Seperti yang dicatat oleh CRO bank (E4):

> *"Nah, Anda mungkin akan terkejut, tetapi Anda cukup menjalin kontak dan berbicara dengan bank-bank internasional lainnya tentang risiko siber dan risiko lainnya. [...]Kedengarannya agak berlawanan dengan intuisi karena, pada akhirnya, ini tentang persaingan, tetapi ini bukan topik persaingan; ini tentang bagaimana membuat industri ini aman. Atau bagaimana Anda menetapkan standar yang bermanfaat bagi semua orang, termasuk klien."*

Pengaruh peniruan tampak sangat kuat dalam membentuk praktik lini ketiga, di mana perusahaan melibatkan penyedia eksternal yang sama untuk melakukan audit keamanan siber. Menariknya, salah satu responden menyoroti beberapa potensi kelemahan dari pendekatan ini karena konflik kepentingan dapat muncul yang memaksa organisasi untuk kembali ke pasar untuk mengidentifikasi penyedia lain. Masalah independensi juga berarti bahwa konsultan eksternal juga melakukan penilaian kematangan.

Kekuatan mimetik juga termanifestasi melalui berbagai peran yang mungkin dipegang oleh seorang profesional (terutama di tingkat Dewan Direksi) dalam berbagai situasi.

organisasi. Misalnya, seorang anggota Dewan (A2, Komite Risiko dan Audit) menjelaskan bahwa ia adalah anggota Dewan Direksi di berbagai industri dan merekomendasikan untuk mengadakan 'briefing siber' khusus tentang CS untuk tujuan audit. Ketua Komite Risiko Bank (E2) duduk di Dewan Direksi tiga bank, dua di antaranya ditetapkan sebagai bank penting secara sistemik di Zona Euro. Ia menyarankan agar bank dan Dewan Direksinya mengambil *"pendekatan yang serupa, sangat serupa"*Dengan cara ini, format pengarahan direplikasi di beberapa organisasi sesuai dengan masukan dari anggota Dewan. Meniru praktik perusahaan lain juga muncul karena para profesional berinteraksi di berbagai organisasi dan mentransfer pengetahuan.

Cara lain yang digunakan organisasi untuk meniru praktik satu sama lain adalah melalui asosiasi industri. Seorang responden dari Universitas menyoroti bagaimana praktik terbaik lebih mudah dibagikan antar universitas melalui AusCERT (Australian Computer Emergency Response Team, sebuah organisasi nirlaba yang menyediakan layanan respons siber) atau anggotanya.[6]Demikian pula, dalam industri perbankan, praktik dan pengetahuan dibagikan secara luas melalui Asosiasi Bank nasional. Di sini, para profesional dari semua bank yang terlibat dalam TI dan manajemen risiko siber berbagi praktik di Forum Keamanan dan Komite TI. Lebih lanjut, 12 bank melalui Asosiasi Bank telah bersama-sama menugaskan tinjauan jaminan siber terhadap sebuah organisasi yang memproses pembayaran, yang merupakan proses penting bagi bank-bank tersebut.

Secara keseluruhan, meskipun kekuatan mimetik ditemukan sebagai faktor kuat dalam pemilihan praktik dan struktur pelaporan dalam konfigurasi CS, hal itu tidak berarti bahwa peran dalam 5 LoA perlu dipisahkan secara jelas. Motif efisiensi dan efektivitas sangat berinteraksi dengan kekhawatiran legitimasi: organisasi membandingkan diri dengan organisasi lain tidak hanya untuk melegitimasi tingkat investasi mereka dalam manajemen risiko CS, tetapi juga untuk meningkatkan efisiensi dan efektivitas manajemen risiko CS mereka. Kekhawatiran efisiensi dan efektivitas menjadi sangat menonjol ketika organisasi bekerja sama dengan rekan-rekan industrinya untuk menetapkan praktik tolok ukur. Keputusan tentang jenis adopsi 5 LoA dalam mengkonfigurasi tata kelola CS bergantung pada kompleksitas, eksposur, dan ukuran organisasi.

4.2.2. Kekuatan normatif dimoderasi oleh motif efisiensi/efektivitas

Kekuatan normatif termanifestasi melalui sertifikasi profesional, akreditasi, dan latar belakang pendidikan para profesional. Responden kami dicirikan oleh portofolio pengalaman pendidikan dan profesional yang beragam. Seperti yang diharapkan, para profesional dengan kompetensi teknis paling tinggi (dengan latar belakang akademis di bidang Ilmu Komputer dan/atau TI dan sertifikasi profesional seperti CISP atau CISM) ditempatkan di baris pertama dan kedua (khususnya, tetapi tidak harus CISO/CIO).

Latar belakang akademis dari banyak manajer lini kedua lainnya di bidang keamanan dan manajemen risiko sangat beragam, mulai dari sistem informasi, akuntansi dan keuangan hingga disiplin ilmu lain yang terkait dengan bisnis inti organisasi. Para profesional ini dilatih untuk pekerjaan tersebut melalui pengalaman dan berbagai kualifikasi profesional (siber, akuntansi, keselamatan, dan manajemen risiko)..Latar belakang akademis auditor internal di organisasi yang berpartisipasi bukanlah di bidang ilmu komputer atau sistem informasi, melainkan didominasi oleh akuntansi. Namun, dalam audit internal, auditor TI telah dilatih untuk melakukan audit siber dengan memperoleh sertifikasi CISA dan sertifikasi lainnya. Dari organisasi yang berpartisipasi, para profesional di tiga lini dan Dewan Direksi dengan kualifikasi siber yang paling terfokus adalah mereka yang berada di Bank, menunjukkan bahwa kekuatan paksaan turut memengaruhi kekuatan normatif dan mendorong perekrutan serta sertifikasi para ahli siber. Secara keseluruhan, untuk peran lini kedua dan ketiga, pengalaman tampaknya paling diperhitungkan, sementara kompetensi teknis lebih dominan pada peran lini pertama.

Data yang dikumpulkan menyoroti bahwa responden memiliki tingkat pemahaman yang berbeda-beda terhadap 5 LoA (Level of Action). Meskipun beberapa responden menyadarinya, penggunaannya dalam praktik organisasi tampak terfragmentasi; yaitu, dua lini pertama tercampur, dan lini di atasnya hanya terlibat secara moderat. Beberapa responden menunjukkan pemahaman tentang penerapan model tersebut tergantung pada konteks organisasi:

> "*IIA telah mengeluarkan panduan baru tentang tiga lini pertahanan, yang sedikit lebih fleksibel. Pembagian tanggung jawab yang kaku antara tiga lini pertahanan cocok untuk lembaga keuangan yang memiliki banyak karyawan di bidang tersebut, tetapi organisasi kami lebih kecil dan membutuhkan lebih banyak fleksibilitas tentang bagaimana bidang-bidang tersebut dikelola."*C2 (Manajer Keselamatan dan Keamanan)

Namun, beberapa responden, khususnya mereka yang memiliki latar belakang teknis dari dua lini pertama, tampaknya tidak familiar dengan 5 LoA maupun menyadari pemisahan lini tersebut. Mereka lebih khawatir tentang kecepatan reaksi dalam struktur seperti itu:

> *"Level satu, level dua, level tiga mungkin merupakan formula yang terlalu lambat untuk merespons. Struktur yang berjalan naik dalam rantai tersebut, pada saat sampai ke seseorang yang benar-benar tahu apa yang mereka lakukan, peluangnya sudah hilang.".* B4 (Manajer Tim CS)

Responden lain juga mempertimbangkan hal serupa:

> *"Taksonomi TLM tidak sesuai untuk keamanan siber;; taksonomi ini tidak menyediakan kategori yang cukup untuk mengukur hasil dengan benar dan memastikan bahwa Anda memiliki proses perbaikan yang tepat berdasarkan kategori untuk mencapai hasil tertentu. Jadi, saat ini kami sedang berupaya menyelaraskan taksonomi keamanan siber standar industri dengan risiko kelompok."*(D3, CISO).

Selain itu, perubahan keadaan yang cepat menuntut perubahan definisi peran yang juga cepat:

> *"Ketika kami memulai perjalanan ini, kami menetapkannya sedemikian rupa sehingga kami akan memiliki sejumlah peran. Tiga tahun kemudian, kami memiliki peran yang sama sekali berbeda karena sifat ancaman telah berubah, dan dari mana ancaman itu berasal, serta apa yang diperlukan untuk menghadapinya. Ini bersifat dinamis."* (C5, Chief Information Officer (CIO)).

[6]https://auscert.org.au/.

Secara keseluruhan, karena lini pertama dan kedua tidak terlalu familiar dengan 5 LoA tetapi tampaknya sangat berpengaruh dalam mengkonfigurasi struktur tata kelola CS, mereka bukanlah kekuatan pendorong untuk mempromosikan 5 LoA. Sebaliknya, mereka tampaknya lebih termotivasi oleh motif efisiensi dan efektivitas dan tidak melihat adanya konflik kepentingan antara kedua lini mereka yang memerlukan pemisahan yang ketat. Model ini lebih banyak diikuti di mana para manajer familiar dengannya, sedangkan auditor internal yang juga menyadari 5 LoA sendiri tidak terintegrasi dengan baik dalam manajemen risiko CS di organisasi yang berpartisipasi.

4.2.3. Kekuatan koersif

Kami menemukan bahwa kekuatan koersif seperti yang timbul dari hukum dan peraturan memengaruhi konfigurasi tata kelola CS dengan cara yang berbeda. Bank (E) beroperasi di lingkungan yang paling diatur dan tunduk pada GDPR dan peraturan kehati-hatian yang mengatur manajemen risiko. Sebagai bank sistemik di Zona Euro, Bank tersebut terus dipantau oleh tim pengawas gabungan (JST) dari Bank Sentral Eropa (ECB) dan Bank Sentral negara tempat Bank tersebut berkantor pusat.[7]Di antara organisasi yang berpartisipasi, bank (E) adalah satu-satunya organisasi yang sangat menyadari perlunya pemisahan lini kredit. Regulasi kehati-hatian Eropa mensyaratkan pemisahan lini kredit dan seorang Chief Information Security Officer (CISO) yang melapor langsung kepada Dewan Direksi (BoD).EBA, 2019Bank tersebut jelas mengikuti prinsip pemisahan lini dan telah mengadopsi 5 LoA (Limited Action) hingga tingkat tertinggi di antara organisasi yang berpartisipasi. Namun, dalam beberapa tahun terakhir, praktik Bank tersebut melampaui persyaratan peraturan, dan peraturan tidak dianggap sebagai kekuatan yang paling menentukan dalam mendorong pengembangan manajemen risiko siber. Sebaliknya, motif normatif, mimetik, dan efisiensi/efektivitas lebih dominan.

Standar keamanan industri (misalnya, PCI dan PII) juga merupakan sumber penting tekanan paksaan dalam manajemen risiko CS. Bagi organisasi Ritel (C) dan Bank (E) dengan banyak gerai yang bergantung pada sistem Point of Sale (POS), kepatuhan terhadap standar ini sangat penting. Lini pertama memastikan kepatuhan dan lini kedua memantaunya. Organisasi juga diaudit setiap tahun oleh penyedia eksternal. Saluran tata kelola pemilik sendiri juga memberikan tekanan paksaan dengan pemerintah negara bagian dan perusahaan induk yang mewajibkan penggunaan kerangka kerja CS tertentu. Tekanan paksaan juga terjadi ketika pemilik pemerintah mewajibkan audit.

Kekhawatiran tentang sanksi dan tanggung jawab pribadi tidak secara langsung diidentifikasi sebagai faktor yang memandu konfigurasi struktur tata kelola CS. Organisasi yang berpartisipasi menganggap bahwa mengikuti tolok ukur dan praktik yang serupa dengan rekan-rekan mereka memberikan perlindungan yang wajar terhadap tanggung jawab perdata, yang juga merupakan kekuatan peniru.

Secara keseluruhan, kekuatan pendorong yang secara langsung mengharuskan adopsi 5 LoA adalah regulasi kehati-hatian di sektor perbankan. Namun, adopsi model 5 LoA dalam kasus ini tampaknya bukan karena alasan legitimasi. Sebaliknya, kesadaran Bank akan pentingnya risiko siber membentuk praktik organisasi untuk mengantisipasi persyaratan regulasi. Bahkan, urutannya mungkin terbalik – model 5 LoA dikembangkan berdasarkan struktur tata kelola di bank dan organisasi besar lainnya yang memiliki sumber daya yang dapat mereka alokasikan untuk manajemen risiko keamanan siber.

4.2.4. Model faktor kelembagaan dan efisiensi/efektivitas untuk adopsi 5 LoA

Berdasarkan temuan kami, kami mengkonseptualisasikan sebuah model yang diambil oleh organisasi dalam mengadopsi 5 LoA sesuai dengan motif efisiensi/efektivitas dan kekuatan institusional yang muncul dalam konteks mereka. Model ini mewakili berbagai jenis konfigurasi tata kelola keamanan siber. Temuan kami menunjukkan bahwa motif efisiensi/efektivitas secara signifikan memoderasi kekuatan institusional, yang saling terkait dan memengaruhi satu sama lain. Misalnya, peraturan kehati-hatian yang mewajibkan adopsi 5 LoA yang dikembangkan oleh profesi itu sendiri secara tidak langsung memengaruhi para profesional untuk memperoleh sertifikasi dan organisasi untuk mempekerjakan profesional yang bersertifikasi. Kekuatan koersif dan normatif lebih berdampak pada pemisahan lini karena mempertahankan pemisahan ini menyoroti adopsi 5 LoA dan meningkatkan legitimasi. Namun, jika pemisahan tidak dianggap efisien, manajemen sering kali menyeimbangkannya dengan menggabungkan peran atau mendorong hubungan informal sehingga 5 LoA menjadi kurang terpisah.

Keseimbangan antara faktor efisiensi/efektivitas dan legitimasi bergantung pada konteks organisasi. DalamGambar 3Kami menguraikan faktor-faktor yang diasumsikan dominan di setiap kuadran yang menunjukkan jenis adopsi dari 5 LoA. Beberapa faktor saling tumpang tindih. Misalnya, pemisahan jalur mungkin disebabkan oleh faktor yang sama pada pengadopsi yang tampak dan pengadopsi eksplisit; namun, faktor-faktor yang mendorong keterlibatan aktif mungkin berbeda, misalnya persepsi paparan. Model yang dihasilkan mengidentifikasi faktor-faktor dalam keputusan yang mendasari pilihan yang dibuat dalam memilih berbagai jenis konfigurasi tata kelola keamanan siber.

5. Diskusi

5.1. Penerapan eksplisit 5 LoA tidak umum

Analisis kami menunjukkan bahwa organisasi baru menyadari pentingnya struktur yang terdefinisi dengan baik dan transparan dalam tata kelola CS dan manajemen risiko. Meskipun kami menemukan bahwa jajaran manajemen tingkat atas lebih familiar dengan berbagai lini akuntabilitas dan mengakui model 5 LoA sebagai praktik yang baik, mereka tidak mendukung penerapan model tersebut secara ketat. Sebagian besar organisasi yang berpartisipasi tidak memisahkan implementasi kontrol dari pemantauannya. Dua lini pertama seringkali jauh lebih rinci dan saling terkait daripada terpisah, dengan tanggung jawab yang khas untuk lini pertama dan kedua dibagi di antara beberapa individu, fungsi, dan unit. Seringkali tanggung jawab lini kedua untuk memantau kontrol dan memberikan jaminan bercampur dengan tugas operasional. Namun, independensi dalam pemantauan kontrol dipastikan oleh wewenang yang diberikan oleh hierarki formal pada

[7]Tim Pengawasan Gabungan menghadiri setiap rapat Dewan Direksi untuk memantau tata kelola dan manajemen risiko, dan selain itu, melakukan tinjauan rutin di lokasi terhadap manajemen risiko di bawah tingkat Dewan Direksi.

Segregation of lines	Ostensible Adoption	Explicit Adoption
Segregated	**Primary motives for segregation of lines** • *Coercive:* GDPR; industry security standards; risk regulation • *Normative:* educational background and experience; cyber security qualifications • *Mimetic:* intelligence partners; external consultants; best practice; shared board appointments **Primary motives for low engagement** • *Efficiency:* low perceived exposure	**Primary motives for segregation of lines** • *Coercive:* GDPR; industry security standards; prudential (risk) regulation • *Normative:* educational background; experience; cyber security qualifications; accreditations • *Mimetic:* intelligence partners; external consultants; best practice; shared board appointments **Primary motives for high engagement** • *Efficiency:* high perceived exposure, large size; high complexity
	No Adoption	**Implicit Adoption**
Blended	**Primary motives for non-adoption** • *Efficiency:* small size, low complexity, low perceived exposure • *Mimetic:* emulating non-adopters	**Primary motives for blending of lines** • *Efficiency:* speed of reaction; flexibility; technical proactiveness • *Mimetic:* intelligence partners; best practice **Primary motives for high engagement** • *Efficiency:* high perceived exposure, medium size; medium complexity
	Low	High

Level of engagement in the five lines of accountability

Gambar 3. Model keamanan siber g Hai konfigurasi tata kelola yang mengidentifikasi faktor-faktor dalam adopsi dari 5 LoA.

Peran CIO/CISO bertindak sebagai pengawas operasional. *secara efisien*sebisa mungkin. Karena alasan ini, mereka tidak sering mengubah struktur tata kelola, karena orang-orang di posisi manajemen risiko siber sering mengubah struktur tata kelola.

Dalam hal memberikan jaminan bahwa perspektif risiko CS dan bagaimana hal itu tertanam dalam keseluruhan dan Fortin, 2013) bahwa auditor internal mendominasi Meskipun organisasi jauh lebih menyadari dengan 5 LoA), mereka melihat perannya sebagai margin. audit internal. Sebagai bagian dari ruang lingkup manajemen risiko siber menurut jadwal audit internal jangka panjang, kemampuan audit untuk memberikan penilaian holistik terhadap c

Mengenai cakupan dan ketepatan waktu audit internal, para manajer eksekutif dan dewan direksi memandang pengungkapan pemahaman tentang ancaman dan perkembangan yang muncul, hal ini menunjukkan nilai jaminan eksternal yang diberikan kepada organisasi di industri yang beroperasi dengan standar tinggi. dkk., 2019) dan benar-benar independen.

Meskipun penurunan kontrol teknis dapat diterima, organisasi yang berpartisipasi menyadari bahwa mereka memiliki pemahaman tingkat tinggi tentang CS.

I Peran-peran tersebut. Organisasi berupaya memberikan solusi siber holistik. e Gabungkan dua baris pertama karena lingkungan siber terus berubah, dan area CS (Critical Science) di organisasi semakin berkembang.

Hai Jika manajemen yang efektif memastikan jalur ketidakstabilan dan pelaporan untuk tujuan manajemen yang efektif, ruang lingkup auditor internal adalah ERM. Temuan kami menguatkan temuan sebelumnya yang Sayang sebagian besar berfokus pada peninjauan kepatuhan terhadap ERM yang Hai ada dan kebutuhan untuk menjaga independensi auditor internal.

A dalam tata kelola CS karena cakupan dan ketepatan waktunya Ment sangat luas, praktik meninjau komponen artinya siklus audit berlangsung selama 4–5 tahun (Slapničar dkk., 2 Efektivitas manajemen risiko siber secara tepat waktu. Jaminan dari para D penasihat, perubahan struktur organisasi yang cepat, dan adanya ketidakpatuhan material terhadap...*secara internal*menetapkan sistem di e industri dan apakah organisasi mereka memiliki peran yang lebih besar. Penyedia eksternal memiliki keuntungan karena mengetahui teknologi M serupa dan rentan terhadap kesalahan yang sama.

e Pendekatan berbasis bottom-up, tata kelola, risiko dan kepatuhan, M pentingnya keterlibatan manajemen eksekutif dalam CS dan menerima laporan yang hanya berisi informasi tingkat tinggi.

kemampuan sebagai*secara efektif* dan perubahan bersifat dinamis, oleh karena itu organisasi membutuhkan daya tarik dan efisiensi. untuk meninjaunya dari suatu proses Héroux dan Fortin (Pahlawan kebijakan dan kerangka kerja. fungsi audit internal (sesuai dengan pekerjaan yang dilakukan oleh fungsi ini setiap tahun 022Hal ini menghambat internal

Faktor-faktor dan lingkungan berarti hal-hal tersebut kurang penting dibandingkan dengan di atasnya. Pandangan ini melihat pendekatan metode-metode lain yang digunakan (Gilligan

perlu diatur untuk manajemen risiko; namun, informasi. Hal ini menghambat

Keterlibatan proaktif manajemen eksekutif. Para manajer eksekutif secara kolektif terlibat dalam manajemen risiko CS dalam komite khusus dan sangat bergantung pada CIO/CISO dan spesialis keamanan mereka. Masalah dengan pelaporan 'dorongan' semacam itu adalah bahwa isi laporan dan tingkat kekritisan informasi ditentukan oleh mereka yang mengelola CS dan yang seringkali menahan informasi penting terlalu lama (Martin, 2014; Srinivasan dkk., 2016).Aghion dan Tirole (1997)berpendapat bahwa hubungan semacam itu menyebabkan perbedaan antara wewenang formal ("hak untuk memutuskan") dan wewenang nyata ("kontrol efektif atas keputusan"), yang sebagian besar berada di tangan CIO/CISO.

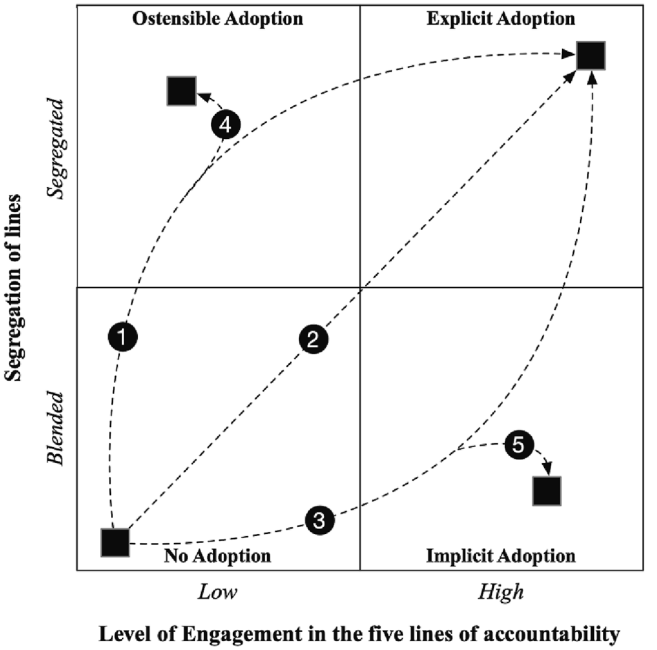
Temuan kami menunjukkan bahwa Dewan Direksi belum mengemban tanggung jawab lini kelima karena mereka relatif pasif dalam menerima laporan siber, alih-alih berada dalam posisi untuk secara konstruktif menantang laporan tersebut dan memberikan pandangan independen. Untuk melampaui apa yang telah terjadiLyons (2011) panggilan*"lebih dari sekadar formalitas belaka"*Oleh karena itu, sangat penting bagi Dewan Direksi untuk memperoleh kompetensi dan pengalaman di bidang siber/digital/TI, karena jika tidak, lini kelima tidak dapat menjadi lini akuntabilitas yang independen. Tampaknya otoritas pasar modal telah mulai menyadari bahwa kontribusi Dewan Direksi seringkali terlalu rendah. Pada saat penulisan ini, Komisi Sekuritas dan Bursa AS (SEC, 2022(Komisi Sekuritas dan Bursa AS) telah mengusulkan aturan baru yang mewajibkan pengungkapan pengawasan direksi terhadap risiko tanggung jawab sosial perusahaan (CSR), peran manajemen dalam menerapkan kebijakan dan prosedur CSR, serta keahlian CSR dari para manajer dan direksi. Regulasi semacam itu kemungkinan akan mendorong keterlibatan proaktif manajemen eksekutif dan direksi dalam tata kelola CSR melalui tekanan dari investor dan dampak nyata pada biaya modal.

Secara keseluruhan, di antara organisasi yang kami teliti, tampaknya tidak ada yang berada di kuadran 'Tidak mengadopsi' (Gambar 4Kami mengklasifikasikan organisasi B (Kesehatan), C (Rantai ritel), dan D (Penyedia layanan TI) dalam kuadran 'adopsi implisit' karena lini pertama dan kedua yang tercampur dan dengan keterlibatan yang agak kurang dari manajemen eksekutif dan Dewan Direksi. Kami tidak mengklasifikasikan organisasi mana pun sebagai memiliki lini yang terpisah dan keterlibatan tinggi. Bank (E) memiliki pemisahan yang paling jelas antara lini akuntabilitas, diikuti oleh Universitas (A), tetapi kami tetap mengklasifikasikan keduanya sebagai berada di antara pengadopsi 'tampak' dan 'eksplisit', karena mereka belum sepenuhnya menerapkan semua peran. Keputusan konfigurasi tata kelola CS mereka mencerminkan campuran motif legitimasi dan efisiensi/efektivitas.

5.2. Model jalur adopsi 5 LoA

Salah satu wawasan utama dari temuan kami adalah bahwa adopsi model 5 LoA dalam konteks konfigurasi tata kelola CS bersifat berkembang dan dinamis. Jenis adopsi yang saat ini dilakukan oleh organisasi dan jenis adopsi yang ingin mereka implementasikan bergantung pada efek interaktif dari kekuatan kelembagaan dan motif efisiensi/efektivitas dalam menghadapi sifat ancaman siber yang dinamis dan berubah-ubah yang menyebabkan organisasi mengatur tata kelola CS mereka agar dinamis – yaitu, lincah dan adaptif. Organisasi mencari fleksibilitas yang lebih besar (Eulerich, 2021) dengan 'menggabungkan' peran-peran yang terpisah dalam model 5 LoA untuk memastikan reaksi cepat terhadap perubahan keadaan. Namun, terlepas dari jumlah lini dan sejauh mana penggabungan lini tersebut, kami menemukan bahwa semua organisasi melihat ruang lingkup untuk meningkatkan keterlibatan dalam peran 5 LoA.

Berdasarkan temuan kami, kami mengembangkan model jalur (Gambar 4) yang menunjukkan jenis adopsi 5 LoA dari waktu ke waktu dan mencerminkan fluiditas konfigurasi tata kelola CS. Jalur tersebut menunjukkan di mana konfigurasi tata kelola CS suatu organisasi berada, dan jenis adopsi yang ditargetkan. Kekuatan institusional mewakili dorongan awal untuk konfigurasi CS yang diadopsi. Artinya, organisasi dengan tata kelola CS yang awalnya belum matang akan mengkonfigurasi adopsi awal 5 LoA mereka sesuai dengan mimetik, koersif, dan normatif.



Gambar 4. Model alur menuju lima jalur akuntabilitas dalam tata kelola keamanan siber.

Namun, seiring waktu, tingkat segregasi dan keterlibatan dalam jalur akuntabilitas dibentuk oleh faktor efisiensi/efektivitas seperti ukuran, persaingan, kompleksitas, atau ketidakpastian. Sebagai jalur yang sebenarnya, konfigurasi CS kemudian dapat beralih untuk mengadopsi jenis adopsi lain seiring waktu karena faktor efisiensi/efektivitas bergeser.

Menurut model alur kami, sebuah organisasi dapat memilih salah satu dari tiga alur utama untuk mengadopsi model 5 LoA. Alur 1 bergerak dari 'tidak mengadopsi' melalui 'adopsi yang tampak' ke 'adopsi eksplisit', dan alur ini akan diambil jika kekuatan institusional lebih dominan daripada motif efisiensi/efektivitas sehingga pemisahan jalur secara formal diimplementasikan, tetapi keterlibatan awalnya belum tinggi. Alur 2 bergerak dari 'tidak mengadopsi' langsung ke 'adopsi eksplisit', dan alur ini akan diambil jika kekuatan koersif dan/atau normatif memerlukan pemisahan jalur sementara motif efisiensi/efektivitas juga memerlukan keterlibatan tinggi dari manajemen eksekutif dan Dewan Direksi. Alur 3 bergerak dari 'tidak mengadopsi' melalui 'adopsi implisit' ke 'adopsi eksplisit', dan alur ini akan diambil ketika motif efisiensi/efektivitas ditekankan daripada kekuatan institusional.

Penting untuk dicatat bahwa tidak semua organisasi bercita-cita untuk 'mengadopsi secara eksplisit' model 5 LoA karena keseimbangan antara motif efisiensi dan faktor kelembagaan mereka. Organisasi mungkin tetap menggunakan adopsi yang tampak atau implisit karena sesuai dengan kebutuhan mereka. Oleh karena itu, model jalur mewakili pilihan ini dengan menunjukkan jalur yang tetap berada dalam kuadran ini (jalur 4 dan jalur 5, masing-masing).

5.3. Implikasi praktis, keterbatasan penelitian, dan peluang penelitian di masa depan

Dari perspektif praktis, studi kami menawarkan beberapa rekomendasi. Organisasi perlu memutuskan sejauh mana penerapan 5 LoA diperlukan dalam konteks mereka untuk memastikan legitimasi tata kelola CS mereka dan untuk memaksimalkan efisiensi dan efektivitas manajemen risiko CS mereka. Dalam pengambilan keputusan, mereka harus mempertimbangkan pemisahan lini dan tingkat keterlibatan dalam peran lini. Berkaitan dengan hal tersebut...*pemisahan jalur*Temuan kami menunjukkan bahwa kelincahan dan efisiensi terutama mendorong konfigurasi tata kelola CS. Di beberapa organisasi, dua lini pertama mungkin tetap menyatu (atau bahkan mungkin hanya ada satu lini), karena memisahkannya dapat memperlambat respons dan secara tidak proporsional mahal dibandingkan dengan ukurannya. Beberapa organisasi memutuskan untuk melakukan cosourcing atau outsourcing beberapa tugas seperti, misalnya, pemindaian lingkungan dan identifikasi ancaman yang muncul. Ketergantungan yang berlebihan pada penyedia internal untuk saran tersebut akan menimbulkan risiko dalam hal kemampuan untuk 'memeriksa kebenaran' bahaya yang muncul dari lingkungan.

Mengenai*tingkat keterlibatan dalam peran lini*Kami percaya bahwa keterlibatan yang lebih tinggi dari lini atas akan sangat bermanfaat. Temuan umum kami adalah bahwa peran auditor internal tidak cukup terintegrasi dalam manajemen risiko CS untuk memanfaatkan keterampilan dan keahlian mereka. Penelitian sebelumnya menunjukkan bahwa manajemen risiko CS dapat jauh lebih efektif jika lini kedua dan ketiga berkolaborasi (Steinbart dkk., 2018Kompetensi auditor internal berbeda dengan kompetensi profesional keamanan, dan kompetensi ini dapat dikombinasikan secara produktif. Misalnya, terdapat peluang dalam penilaian risiko, suatu bidang yang telah berkembang selama beberapa dekade dalam profesi audit internal, atau kuantifikasi nilai aset digital dan dampak serangan siber. Pada saat yang sama, klarifikasi peran akuntabilitas sangat penting untuk menghindari duplikasi tugas atau, yang terburuk dan lebih umum, 'kekosongan' berbahaya dalam fungsi penjaminan. Peningkatan profesionalisasi lini akuntabilitas kelima (Dewan Direksi) (kekuatan normatif) dapat membantu meningkatkan keterlibatannya dan memfasilitasi manajemen dan tata kelola risiko CS yang lebih holistik. Adapun yang terakhir, pembentukan*ad hoc* Sertifikasi CS untuk anggota dewan dapat memanfaatkan persepsi positif yang secara tradisional dikaitkan dengan sertifikasi siber.

Sebagaimana lazim dalam investigasi kualitatif, temuan dari penelitian kami memiliki keterbatasan generalisasi. Secara khusus, organisasi yang berpartisipasi dalam penelitian ini termasuk dalam industri tertentu, yang mungkin tidak mewakili dinamika yang terkait dengan manajemen risiko CS di sektor lain. Selain itu, organisasi yang berpartisipasi mewakili satu organisasi per industri, yang dapat membatasi penerapan hasil kami pada organisasi lain di sektor yang sama. Keterbatasan lain yang diakui adalah pendekatan pengambilan sampel bertujuan yang diadopsi, yang mungkin menimbulkan bias pengambilan sampel.Patton, 2014Secara khusus, responden yang dipilih, karena kompetensi mereka dalam manajemen risiko tanggung jawab sosial perusahaan (CS), mungkin tidak mewakili praktik dan persepsi seputar manajemen risiko CS di organisasi mereka. Untuk mengimbangi keterbatasan ini, kami berupaya mewawancarai lebih banyak profesional di setiap organisasi; lebih lanjut, kami merekrut organisasi besar untuk dapat memperoleh pemahaman yang lebih baik tentang bagaimana garis akuntabilitas 'dijalankan' di masing-masing organisasi. Keterbatasan ketiga adalah endogenitas model yang diusulkan di mana efektivitas dapat dianggap sebagai variabel independen yang mendorong keputusan tentang konfigurasi CS, tetapi juga dapat menjadi variabel dependen; yaitu, hasil dari konfigurasi tata kelola CS.

Studi ini menawarkan beberapa peluang untuk penelitian di masa mendatang. Misalnya, model faktor adopsi 5 LoA dalam mengkonfigurasi tata kelola CS dan model jalur konfigurasi tata kelola CS dapat diuji melalui analisis longitudinal dan/atau lintas sektoral. Peluangnya adalah untuk lebih lanjut memeriksa hubungan moderasi antara kekuatan institusional dan motif efisiensi pada manajemen risiko dan tata kelola CS dengan pemodelan persamaan struktural. Terakhir, pertanyaan tentang apakah adopsi eksplisit 5 LoA penting untuk hasil siber dapat dipelajari dengan menggunakan metode kuantitatif yang dapat menguji kausalitas. Misalnya, salah satu jalur penelitian adalah apakah pernyataan eksplisit mengenai risiko keamanan siber dalam piagam Dewan Direksi diperlukan untuk tata kelola CS yang efektif. Demikian pula, penelitian di masa mendatang dapat mempertimbangkan apakah dokumentasi organisasi harus menguraikan 5 LoA untuk mencapai manfaat dari model 5 LoA.

6. Kesimpulan

Kesimpulannya, konfigurasi tata kelola siber dan hubungan antara 5 LoA (Level of Action) di berbagai industri masih kurang mendapat perhatian dalam penelitian akademis yang berfokus pada manajemen risiko keamanan siber. Sejauh pengetahuan kami, studi ini adalah yang pertama yang mengkaji topik-topik ini secara komprehensif. Investigasi kami juga telah menyoroti kekuatan-kekuatan yang terutama berkontribusi dalam membentuk konfigurasi dan hubungan ini, serta menawarkan rekomendasi bagi para praktisi dan peneliti.

Pernyataan kontribusi kepenulisan CRediT

Sergeja Slapničar: Konseptualisasi, Metodologi, Investigasi, Penulisan – draf asli, Administrasi proyek.**Micheal Axelsen:** Konseptualisasi, Metodologi, Investigasi, Penulisan – draf asli.**Ivano Bongiovanni:**Metodologi, Investigasi, Penulisan – draf asli. **David Stockdale:**Penulisan – peninjauan & penyuntingan, Administrasi proyek.

Pernyataan Konflik Kepentingan

Para penulis menyatakan bahwa mereka tidak memiliki kepentingan finansial yang bersaing atau hubungan pribadi yang diketahui yang dapat dianggap memengaruhi pekerjaan yang dilaporkan dalam makalah ini.

Ketersediaan data

Para penulis tidak memiliki izin untuk membagikan data.

Ucapan Terima Kasih

Kami mengucapkan terima kasih kepada semua narasumber, Vivian Pontes atas bantuan penelitiannya yang berharga, dan Sekolah Bisnis Universitas Queensland atas Hibah Connect yang mendanai penelitian kami.

Lampiran A: Fungsi, tingkat, dan latar belakang responden

Kode	Fungsi	Tingkat	Latar Belakang Akademik/Sertifikasi
A1	Direktur Operasional (COO)	Eksekutif Pengelolaan	Sekolah Hukum
A2	Ketua Komite Audit dan Risiko	Papan	Magister Perdagangan, Jurusan Akuntansi
A3	Manajer Risiko dan Tata Kelola,	2	Magister Manajemen Keuangan, spesialis manajemen risiko dan pencegahan
A4	Kepala Bagian Teknologi Informasi	2	penipuan, Magister Ilmu Rekayasa
A5	(CIO), Arsitek Siber	1	Sarjana Ilmu Komputer
A6	Auditor Internal	3	Magister Teknologi Informasi, Sarjana Teknik Elektro. Kualifikasi CISA di dalam IAF, tetapi bukan CAE.
B1	Kepala Bagian Teknologi (CTO)	2	Sarjana Teknik Elektronika, sertifikasi Keamanan Siber, Klinisi,
B2	Kepala Bagian Informasi Klinis	2	Kedokteran
B3	Audit Internal	3	Sarjana Perdagangan, CISA
B4	Kepala Tim CS	1 dan 2	Sarjana Bisnis, Magister Ilmu Komputer, CISM
B5	Wakil Ketua Komite Risiko Audit	Papan	Sarjana Bisnis (Akuntansi), Anggota CPA Australia, Penasihat Pajak Bersertifikat, GAICD.
C1	Kepala Platform Keamanan	Eksekutif Pengelolaan	Sarjana Ilmu Komputer, Magister Teknologi Informasi, CISP, CISM, OSCP
C2	Kepala Keamanan dan Keselamatan,	1 dan 2	Sarjana Kimia, Magister Hukum Kesehatan dan
C3	Kepala Keuangan, Kepatuhan, dan Hukum	Eksekutif Pengelolaan	Keselamatan Kerja
C4	Kepala Keamanan dan Operasi, Kepala	1 dan 2	Sarjana Akuntansi dan Sistem Informasi, latar belakang
C5	Bagian Teknologi Informasi (CIO)	Eksekutif Pengelolaan	akademis non-TI, pembelajaran berbasis pengalaman.
D1	Keamanan Operasional -	1 dan 2	Programmer otodidak, tanpa gelar akademis, berpengalaman, bersertifikasi
D2	Kepatuhan Keamanan Informasi	1 dan 2	Sarjana Akuntansi, Sertifikat IIA, CISA, CRISC, Pemeriksa Forensik, pelatihan khusus vendor.
D3	Kepala Bagian Keamanan Informasi (CISO)	Eksekutif Pengelolaan	Tidak memiliki gelar akademis, pengalaman di bidang penegakan hukum dan keamanan siber.
E1	Auditor TI	3	Sarjana Ilmu Komputer, CISA, ISO
E2	Ketua Komite Risiko Dewan Direksi,	Papan	Magister Fisika, Pelatihan tata kelola keamanan siber untuk Dewan
E3	CISO	2	Direksi, Sarjana Ilmu Komputer, CISM, CISSA,
E4	Kepala Bagian Manajemen Risiko	Eksekutif Pengelolaan	Sarjana Bisnis dan Ekonomi
E5	Manajer Keamanan TI	1	Sarjana Teknik Elektro, berbagai sertifikasi, ISO, ISACA, khusus vendor.

Lampiran B: Struktur data untuk pengkodean

Kode (Konsep tingkat pertama)	Konsep tingkat kedua	Dimensi agregat
Deteksi dan respons insiden,	baris pertama	Struktur tata kelola
manajemen kerentanan,		
manajemen vendor.		
Pengujian penetrasi		
Pemilihan dan implementasi kontrol keamanan		
Pengembangan operasional		
Arsitektur keamanan		
Otomatisasi sistem		
Pengujian produk keamanan		
Pengembangan proses seputar topik spesifik;		
Pengembangan kebijakan dan strategi untuk operasional;	baris ke-2	
Fungsi kepatuhan keamanan siber dan informasi;		
Pemantauan kontrol keamanan siber.		
Menganalisis tingkat paparan organisasi.		
Keputusan defensif yang penting.		
Memastikan integrasi manajemen risiko siber dengan ERM; Mengembangkan		
rencana keberlangsungan bisnis dan perencanaan penanggulangan bencana;		
Mengembangkan indikator risiko utama dan pelaporan.		
Tolok ukur kinerja Penilaian	baris ke-2 dan ke-3	
risiko		
Mengelola penyedia penjaminan eksternal		
Memastikan efektivitas manajemen risiko CS dan keselarasan dengan ERM.	baris ke-3	
Mengalokasikan sumber daya untuk manajemen risiko CS.	Manajemen eksekutif	
Mengembangkan/mendukung strategi, kebijakan, dan		
metrik ERM. Mengontrol kinerja manajemen risiko CS.		
Mengawasi manajemen risiko CS.	Dewan direksi	
Memberikan arahan dari pimpinan tertinggi.		
Mengevaluasi kinerja manajemen senior		
Memberikan umpan balik tentang KPI		
Penilaian risiko terpisah untuk tujuan yang berbeda; Tugas	baris ke-2 dan ke-3	Tata kelola relasional
gabungan antara lini pertama dan kedua; Ketergantungan	baris ke-1 dan ke-2	mekanisme
berlebihan pada CIO.	baris ke-4	
Kurangnya pemahaman tentang peran auditor internal; Hubungan	Jalur ke-1, ke-2, ke-4, dan ke-5; Jalur	
informal yang terlalu dekat antara peran yang secara formal dipisahkan;	ke-1, ke-2, dan (lebih jarang) ke-3;	
Layanan seperti SOC, patch, dan intelijen.	Penyedia eksternal.	Kekuatan mimetik
Pembandingan kinerja		
Mengevaluasi kematangan manajemen risiko CS		
Memperkenalkan pemisahan peran lini		
Seorang anggota dewan yang menduduki beberapa posisi di dewan.	Para profesional dari suatu organisasi	
Pergerakan para profesional di berbagai industri dan organisasi. Para profesional berbagi		
praktik terbaik secara terbuka dengan rekan-rekan mereka.		
Kerja sama dengan asosiasi industri yang bergerak di bidang manajemen risiko CS	Asosiasi industri	
(Cyber Security), ilmu komputer, TI, sistem informasi, manajemen risiko, CISO,	Latar belakang akademis	Kekuatan normatif
CISM, CIMA, CISSO, auditor internal bersertifikat, dan lain-lain.	Sertifikasi profesional	
Berpengalaman di berbagai posisi manajemen risiko, sistem informasi, dan layanan pelanggan.	Pengembangan melalui pengalaman	
Regulasi kehati-hatian	Regulasi CS dan privasi	Kekuatan koersif
Peraturan CS		
PCI, PII, persyaratan audit,		
mewajibkan kerangka kerja	Persyaratan pemilik	
CS, melakukan audit.		
Mengintegrasikan organisasi tertentu ke dalam struktur organisasi perusahaan induk.		
struktur		
Ukuran		Motivasi efisiensi/efektivitas
Kompleksitas		
Paparan risiko siber (ketidakpastian lingkungan)		
Persaingan		
Struktur organisasi		

Lampiran C. Data tambahan

Data tambahan untuk artikel ini dapat ditemukan secara online dihttps://doi.org/10.1016/j.accinf.2023.100642.

Referensi

ACCA, dan CAANZ, 2019. Keamanan Siber dan CFO. https://www.charteredaccountantsanz.com/-/media/a82de353ba15474ead28028e53b5b416.ashx. Aghion, P., Tirole, J., 1997. Otoritas formal dan nyata dalam organisasi. J. Polit. Econ. 105 (1), 1–29.

AICPA, 2017. Pelaporan tentang program dan kontrol manajemen risiko keamanan siber suatu entitas. https://www.aicpa.org/cpe-learning/publication/reporting-on-an-Panduan Pengesahan Program dan Kontrol Manajemen Risiko Keamanan Siber Entitas (OPL).

Ali, MI, Kaur, S., Khamparia, A., Gupta, D., Kumar, S., Khanna, A., Al-Turjman, F., 2020. Tantangan keamanan dan ekosistem forensik siber dalam BYOD yang didorong oleh IoT Lingkungan. IEEE Access 8, 172770–172782.

Institut Direksi Perusahaan Australia (AICD) dan Pusat Penelitian Kerja Sama Keamanan Siber, 2022. Prinsip-Prinsip Tata Kelola Keamanan Siber. https://www.aicd.com.au/risk-management/framework/cyber-security/cyber-security-governance-principles.html.

Institut Direksi Perusahaan Australia, & Pusat Penelitian Kerja Sama Keamanan Siber, 2022. Prinsip Tata Kelola Keamanan Siber https://www.aicd.com.au/content/dam/aicd/pdf/tools-resources/director-tools/board/cyber-security-governance-principles-web3.pdf.

Barton, KA, Tejay, G., Lane, M., Terrell, S., 2016. Komitmen keamanan sistem informasi: Sebuah studi tentang pengaruh eksternal pada manajemen senior. Comput. Secur. 59, 9–25.

Komite Basel tentang Pengawasan Perbankan, 2011. Prinsip-prinsip untuk Manajemen Risiko Operasional yang Baik. https://www.bis.org/publ/bcbs195.htm.

Komite Basel tentang Pengawasan Perbankan, 2021. Prinsip-prinsip untuk Manajemen Risiko Operasional yang Baik. https://www.bis.org/publ/bcbs195.htm.

Benaroch, M., Chernobai, A., 2017. Kegagalan TI operasional, penghancuran nilai TI, dan perubahan tata kelola TI tingkat dewan direksi. MIS Q. 41 (3), 729–762.https://doi.org/10.25300/MISQ/2017/41.3.04.

Burdon, WM, Sorour, MK, 2020. Teori Institusional dan evolusi budaya kepatuhan yang 'sah': Studi kasus sektor jasa keuangan Inggris. J. Bus. Ethics 162 (1), 47–80.https://doi.org/10.1007/s10551-018-3981-4. Coase,

RH, 1937. Sifat perusahaan. Economica 4 (16), 386–405.

COBIT, 2019. Kerangka Kerja ISACA. Tersedia di https://www.isaca.org/resources/cobit.

Komite Organisasi Sponsor Komisi Tredway (COSO), 2004. Manajemen Risiko Perusahaan—Kerangka Kerja Terintegrasi. COSO, Washington, DC. Komite Organisasi Sponsor Komisi Tredway (COSO), 2013. Pengendalian Internal—Kerangka Kerja Terintegrasi. COSO, Washington, DC. Komite Organisasi Sponsor Komisi Tredway (COSO), 2017. Manajemen Risiko Perusahaan: Mengintegrasikan dengan Strategi dan Kinerja. COSO, Washington, DC.

Constantino, TE, 2008. Ensiklopedia Metode Penelitian Kualitatif SAGE. SAGE Publications Inc, Thousand Oaks, California.

De Haes, S., Van Grembergen, W., 2009. Studi eksplorasi tentang implementasi tata kelola TI dan dampaknya terhadap keselarasan bisnis/TI. Inf. Syst. Manag. 26 (2), 123–137.https://doi.org/10.1080/10580530902794786.

Deloitte, 2015. COSO di era siber. https://www.coso.org/documents/COSO%20in%20the%20Cyber%20Age_FULL_r11.pdf.

DiMaggio, PJ, Powell, WW, 1983. Sangkar besi ditinjau kembali: Isomorfisme institusional dan rasionalitas kolektif dalam bidang organisasi. Am. Sociol. Rev. 48 (2), 147–160.

Dzuranin, AC, Mălăescu, I., 2016. Keadaan saat ini dan arah masa depan audit TI: Tantangan dan peluang. J. Inform. Syst. 30 (1), 7–20.https://doi.org/10.2308/isys-51315.

Eulerich, M., 2021. Model tiga garis baru untuk penataan tata kelola perusahaan – Diskusi kritis tentang persamaan dan perbedaan. Kepemilikan dan Pengendalian Perusahaan. 18 (2), 180–187.https://doi.org/10.22495/cocv18i2art15.

Otoritas Perbankan Eropa (EBA), 2019.*Pedoman tentang teknologi informasi dan komunikasi (TIK) dan manajemen risiko keamanan*.https://www.eba.europa.eu/sites/default/ documents/files/document_library/Publications/Guidelines/2020/GLs%20on%20ICT%20and%20security%20risk%20management/872936/Final%20draft%20Guidelines%20on%20ICT%20and%20security%20risk%20management.pdf.

EY, dan Institute of Internal Auditors, 2021. Enam hal yang berisiko. Pertanyaan-pertanyaan kunci untuk mengungkap kesenjangan pemahaman dewan direksi tentang ketahanan siber organisasi. https://global.theiia.org/knowledge/Public%20Documents/EY-The-Risky-Six-Board-Disconnections.pdf.

Feng, C., Wang, T., 2018. Apakah selera risiko CIO penting? Bukti dari insiden pelanggaran keamanan informasi. Int. J. Account. Inf. Syst. 32 (1), 59–75. Freeman, T., Peck,

E., 2007. Melaksanakan tata kelola: Dramaturgi dewan kemitraan. Administrasi Publik 85 (4), 907–929.

Gale, M., Bongiovanni, I., Slapničar, S., 2022. Mengatur keamanan siber dari ruang rapat: tantangan, pendorong, dan jalan ke depan. Comput. Secur. 121, 102840 https://doi.org/10.1016/j.cose.2022.102840.

Gilligan, M., Herrygers, S., Rau, K., 2019. Mengelola risiko siber di era digital. https://www.coso.org/Documents/COSO-Deloitte-Managing-Cyber-Risk-in-a-DigitalAge.pdf.

Gioia, DA, Corley, KG, Hamilton, AL, 2013. Mencari Ketelitian Kualitatif dalam Penelitian Induktif. Organ. Res. Methods 16, 15–31.

Gordon, LA, Loeb, MP, Tseng, CY, 2009. Manajemen risiko perusahaan dan kinerja perusahaan: Perspektif kontingensi. J. Account. Public Policy 28 (4), 301–327.

Granovetter, M., 1985. Tindakan Ekonomi dan Struktur Sosial: Masalah Keterkaitan. Am. J. Sociol. 91, 481–510.

Haislip, J., Masli, A., Richardson, V., Sanchez, JM, 2016. Memperbaiki legitimasi organisasi setelah kelemahan material teknologi informasi (TI): Eksekutif Perputaran karyawan, keahlian TI, dan peningkatan sistem TI. J. Inf. Syst. 30 (1), 41–70.

Haislip, J., Karim, K., Lin, KJ, Pinsker, R., 2020. Pengaruh keahlian TI CEO dan komite teknologi tingkat dewan terhadap ketepatan waktu pengungkapan Formulir 8-K. J. Inf. Sistem 34 (2), 167–185.

Haislip, J., Karim, K., Lin, KJ, Pinsker, R., 2021. Dampak keahlian TI eksekutif terhadap pelanggaran keamanan data yang dilaporkan. Inform. Syst. Res. 32 (2), 318–334

Harrast, SA, Swaney, AM, 2019. Apa peran komite teknologi tingkat dewan direksi? J. Corporate Account. Finance 30 (4), 43–47.https://doi-org.ezproxy.perpustakaan.uq.edu.au/10.1002/jcaf.22414.

Hartmann, CC, Carmenate, J., 2021. Penelitian akademis tentang peran tata kelola perusahaan dan keahlian TI dalam mengatasi pelanggaran keamanan siber: Implikasi bagi praktik, kebijakan, dan penelitian. Isu-isu Audit Saat Ini 15 (2), A9–A23.https://doi.org/10.2308/CIIA-2020-034.

Héroux, S., Fortin, A., 2013. Fungsi audit internal dalam tata kelola teknologi informasi: Perspektif holistik. J. Inform. Syst. 27 (1), 189–217.https://doi.org/10.2308/isys-50331.

Higgs, JL, Pinsker, RE, Smith, TJ, Young, GR, 2016. Hubungan antara komite teknologi tingkat dewan dan pelanggaran keamanan yang dilaporkan. J. Inform. Syst. 30 (3), 79–98.https://doi.org/10.2308/isys-51402.

Institut Auditor Internal, 2013. Tiga lini pertahanan dalam manajemen dan pengendalian risiko yang efektif. https://na.theiia.org/standards-guidance/Public%20Documents/PP%20The%20Three%20Lines%20of%20Defense%20in%20Effective%20Risk%20Management%20and%20Control.pdf.

Institut Auditor Internal (IIA), 2020. Model Tiga Garis IIA. Pembaruan dari Tiga Garis Pertahanan. https://www.iia.org.au/technical-resources/Panduan profesional/model tiga garis iia.

Institut Auditor Internal (IIA), 2016.*Menilai risiko keamanan siber: peran tiga lini pertahanan*.Diperoleh pada 20 Oktober 2020, darihttps://global.theiia.org/panduan-standar/Dokumen%20Anggota/GTAG-Menilai-Risiko-Keamanan-Siber.pdf.

Organisasi Internasional untuk Standardisasi. Standar Komisi Elektroteknik Internasional (ISO/IEC): ISO/IEC 27001:2013, 2013, Keamanan informasi, Keamanan siber dan perlindungan privasi – Sistem manajemen keamanan informasi – Persyaratan, https://www.iso.org/standard/82875.html. ISACA, 2011.

Model Penilaian Proses COBIT (PAM): Menggunakan COBIT 4.1. ISACA, Padang Rumput Bergulir, IL.

Islam, MS, Farah, N., Stafford, TF, 2018. Faktor-faktor yang terkait dengan audit keamanan/keamanan siber oleh fungsi audit internal. Manag. Audit. J. 33 (4), 377–409.https://doi.org/10.1108/MAJ-07-2017-1595.

Standar Organisasi Internasional untuk Standardisasi / Komisi Elektroteknik Internasional (ISO/IEC): ISO/IEC 27002:2013. Teknologi informasi – Teknik keamanan – Kode praktik untuk pengendalian keamanan informasi.https://www.iso.org/standard/54533.html.

Organisasi Internasional untuk Standardisasi. Standar Komisi Elektroteknik Internasional (ISO/IEC) 27014. 2013. Tata Kelola Keamanan Informasi. https://www.iso.org/standard/43754.html.

Jeyaraj, A., Zadeh, A., 2020. Isomorfisme institusional dalam keamanan siber organisasi: Pendekatan analitik teks. J. Organ. Comput. Electron. Commer. 30 (4), 1–20.

Kahyaoglu, SB, Çaliyurt, K., 2018. Proses penjaminan keamanan siber dari perspektif audit internal. Manag. Audit. J. 33 (4), 360–376.https://doi.org/10.1108/MAJ-02-2018-1804.
Kappelman, L., McLean, E., Johnson, V., Torres, R., 2016. Studi masalah dan tren TI SIM 2015. MIS Q. Exec. 15 (1), 55–83.
Kappelman, L., McLean, E., Johnson, V., Torres, R., Nguyen, Q., Maurer, C., Snyder, M., 2017. Studi masalah dan tren TI SIM 2016. MIS Q. Exec. 16 (1), 47–80KPMG, 2019. Denyut Nadi Fintech Semester Kedua 2019. https://assets.kpmg/content/dam/kpmg/xx/pdf/2020/02/pulse-of-fintech-h2-2019.pdf.
Lankton, N., Price, JB, Karim, M., 2021. Pelanggaran Keamanan Siber dan Peran Tata Kelola Teknologi Informasi dalam Piagam Komite Audit. J. Inform. Syst. 35 (1), 101.https://doi.org/10.2308/isys-18-071.
Lawrence, TB, dan Shadnam, M., 2008. Teori institusional. Ensiklopedia komunikasi internasional. Lee, I., 2021.
Keamanan siber: Kerangka manajemen risiko dan analisis biaya investasi. Bus. Horiz. 64 (5), 659–671.
Leech, T., Hanlon, L., 2016. Tiga garis pertahanan versus lima garis jaminan. Buku Pegangan Tata Kelola Dewan: Panduan Komprehensif untuk Publik, Swasta, dan Anggota Dewan Nirlaba. John Wiley and Sons, New Jersey, hlm. 335–355.
Lin, J., Luo, Z., Luo, X., 2020. Memahami peran tekanan institusional dan inovasi organisasi dalam transformasi kontekstual menuju e-bisnis: Bukti dari perusahaan pertanian. Int. J. Inf. Manag. 51, 102025https://doi.org/10.1016/j.ijinfomgt.2019.10.010.
Lincoln, YS, Lynham, SA, Guba, EG, 2011. Kontroversi paradigmatik, kontradiksi, dan konfluensi yang muncul, ditinjau kembali. Dalam: Denzin, NK, Lincoln, YS (Eds.), Buku pegangan Sage tentang penelitian kualitatif, edisi keempat. Sage Publications, Thousand Oaks, CA, hlm. 97–128Lyons, S.
2011. Pengawasan perusahaan dan garis pertahanan pemangku kepentingan. The Conference Board Executive Action Repo. Machold,
S., Farquhar, S., 2013. Evaluasi tugas dewan: Studi lapangan longitudinal di Inggris. Corp. Gov. 21 (2), 147–164.
Malhotra, Y., 2018. Menjembatani jaringan, sistem, dan kerangka kontrol untuk pengembangan kurikulum dan standar keamanan siber. J. Risiko Operasional. 13 (1), 77–99.https://doi.org/10.21314/JOP.2018.201.
Marshall, C., Rossman, GB, 2011. Merancang penelitian kualitatif, edisi kelima. Sage Publications, Thousand Oaks, CA.
Martin, S. 2014. Keamanan Siber: 60% Teknisi Tidak Memberitahu Atasan Tentang Pelanggaran Kecuali Jika Itu 'Serius'. https://www.ibtimes.co.uk/cyber-security-60-techies-dont-Beritahu atasan tentang pelanggaran kecuali jika itu serius-1445072.
Survei Global McKinsey. 2018.*Saatnya bagi dewan direksi untuk bertindak*.https://www.mckinsey.com/business-functions/strategy-and-corporate-finance/our-insights/a-time-for-dewan-untuk-bertindak.
Nasdaq dan Tanium, 2016. Kesenjangan akuntabilitas: Keamanan siber dan membangun budaya tanggung jawab, https://www.eidebailly.com/-/media/eide-bailly/website-layanan/keamanan-siber/makalah_penelitian_keamanan_siber_-_kesenjangan_akuntabilitas_-_ringkasan_eksekutif.ashx.
Standar Institut Standar dan Teknologi Nasional AS (NIST); Kerangka Kerja untuk Meningkatkan Keamanan Siber Infrastruktur Kritis. Versi 1.1. 2018. https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.04162018.pdf.
Standar Institut Standar dan Teknologi Nasional AS (NIST): Publikasi Khusus 800-37, Revisi 2 (Draf), Mei 2018. OECD, 2015. Prinsip-
prinsip tata kelola perusahaan G20/OECD. Penerbitan OECD, Paris..
Ogbanufe, O., Kim, DJ, Jones, MC, 2021. Menginformasikan komitmen strategis keamanan siber melalui persepsi manajemen puncak: Peran tekanan institusional. Manajemen Informasi 58 (7), 103507https://doi.org/10.1016/j.im.2021.103507.
Parker, LD, 2008. Pengendalian operasional dan keuangan di ruang rapat: Pandangan orang dalam. Br. J. Manag. 19 (4), 341–374.
Patton, MQ, 2014. Metode Penelitian dan Evaluasi Kualitatif: Mengintegrasikan Teori dan Praktik. Publikasi Sage..
Peck, E., 1995. Kinerja dewan pengawas NHS: Laporan aktor, notulen, dan observasi. Br. J. Manag. 6 (2), 135–156.
Peterson, RR, 2004. Strategi dan taktik integrasi untuk tata kelola teknologi informasi. Dalam: Van Grembergen, W. (Ed.), Strategi untuk Teknologi Informasi Tata Kelola: IGI Global, hlm. 37–80.
Power, M., 2009. Manajemen risiko ketiadaan. Acc. Organ. Soc. 34, 849–855.https://doi.org/10.1016/j.aos.2009.06.001Protiviti,
2013. Menerapkan lima lini pertahanan dalam manajemen risiko. Buletin 5, no. 4.
Roberts, PW, Greenwood, R., 1997. Mengintegrasikan Biaya Transaksi dan Teori Kelembagaan: Menuju Kerangka Efisiensi Terbatas untuk Memahami Adopsi Desain Organisasi. AMR 22 (2), 346–373.
Rothrock, RA, Kaplan, J., Van Der Oord, F., 2018. Peran dewan direksi dalam mengelola risiko keamanan siber. MIT Sloan Manag. Rev. 59 (2), 12–15.
Sambamurthy, V., Zmud, RW, 2000. Komentar Penelitian: Logika pengorganisasian untuk aktivitas TI suatu perusahaan di era digital—Prognosis praktik dan seruan untuk penelitian. Inf. Syst. Res. 11 (2), 105–114.https://doi.org/10.1287/isre.11.2.105.11780.
Komisi Sekuritas dan Bursa (SEC). 2011. Panduan Pengungkapan CF: Topik No. 2 Keamanan Siber. https://www.sec.gov/divisions/corpfin/guidance/cfguidance-topic2.htm.
Komisi Sekuritas dan Bursa (SEC). 2018. Pernyataan dan Pedoman Komisi tentang Pengungkapan Keamanan Siber Perusahaan Publik. https://www.sec.gov/rules/interp/2018/33-10459.pdf.
Komisi Sekuritas dan Bursa (SEC). 2022. Manajemen risiko keamanan siber, strategi, tata kelola, dan pengungkapan insiden. Maret. https://www.sec.gov/rules/proposed/2022/33-11038.pdf.
Škiljić, A., 2020. Keamanan siber dan kerja jarak jauh: (Ketidak)respons Kroasia terhadap meningkatnya ancaman siber. Int. Cybersecur. Law Rev. 1 (1), 51–61.https://doi.org/10.1365/s43439-020-00014-3.
Slapničar, S., Vuko, T., Čular, M., Drašček, M., 2022. Efektivitas audit keamanan siber. Int. J.Akun. Memberitahukan. sistem. 44, 100548https://doi.org/10.1016/j.accinf.2021.100548.
Smith, T., Tadesse, AF, Vincent, NE, 2021. Dampak karakteristik CIO terhadap pelanggaran data. Int. J. Account. Inform. Syst. 43, 100532.
Soomro, ZA, Shah, MH, Ahmed, J., 2016. Manajemen keamanan informasi membutuhkan pendekatan yang lebih holistik: Tinjauan literatur. Int. J. Inf. Manag. 36 (2), 215–225.
Srinivasan, S., Paine, L., Goyal, N., 2016. Pelanggaran Keamanan Siber di Target. Studi Kasus Harvard Business Publishing.
Stafford, T., Deitz, G., Li, Y., 2018. Peran audit internal dan pelatihan pengguna dalam kepatuhan kebijakan keamanan informasi. Manag. Audit. J. 33 (4), 410–424.https://doi.org/10.1108/MAJ-07-2017-1596.
Steinbart, PJ, Raschke, RL, Gal, G., Dilla, WN, 2018. Pengaruh hubungan yang baik antara fungsi audit internal dan keamanan informasi terhadap Hasil keamanan informasi. Acc. Organ. Soc. 71, 15–29.https://doi.org/10.1016/j.aos.2018.04.005.
Van Grembergen, W., De Haes, S., Guldentops, E., 2004. Struktur, proses dan mekanisme relasional untuk tata kelola TI. Dalam: Van Grembergen, W. (Ed.), Strategi untuk Tata Kelola Teknologi Informasi: IGI Global, hlm. 1–36.
Vincent, NE, Higgs, JL, Pinsker, RE, 2019. Faktor-faktor tingkat dewan dan manajemen yang mempengaruhi kematangan praktik manajemen risiko TI. J. Inform. Syst. 33 (3), 117–135.https://doi.org/10.2308/isys-52229.
Von Solms, B., Von Solms, R., 2018. Keamanan siber dan keamanan informasi – apa yang ada di mana? Inform. Comput. Secur. 26 (1), 2–9.https://doi.org/10.1108/ics-04-2017-0025.
Vuko, T., Slapničar, S., Čular, M., Drašček, M., 2021. Pendorong utama efektivitas audit keamanan siber: perspektif neo-institusional. Kertas Kerja SSRN.https://papers.ssrn.com/sol3/papers.cfm?abstract_id=3932177.
Wallace, L., Lin, H., Cefaratti, MA, 2011. Keamanan informasi dan kepatuhan Sarbanes-Oxley: Sebuah studi eksplorasi. J. Inf. Syst. 25 (1), 185–211.https://doi.org/10.2308/jis.2011. 25.1.185.
Walton, S., Wheeler, PR, Zhang, YI, Zhao, XR, 2021. Tinjauan dan analisis integratif penelitian keamanan siber: Keadaan saat ini dan arah masa depan. J. Inform. Sistem 35 (1), 155–186.https://doi.org/10.2308/ISYS-19-033.

Wilkin, CL, Chenhall, RH, 2020. Tata Kelola Teknologi Informasi: Refleksi tentang Masa Lalu dan Arah Masa Depan. J. Inf. Syst. 34 (2), 257–292.
Williamson, O., 1975. Pasar dan hierarki. Free Press, New York. Williamson, OE, 2008. Ekonomi Biaya Transaksi. Springer, Berlin Heidelberg.

Williamson, OE, 2007. Ekonomi Biaya Transaksi: Sebuah Pengantar.*Makalah Diskusi Ekonomi No. 2007-3*[[Online]. Tersedia di: https://ssrn.com/abstrak=1691869 atau https://dx.doi.org/10.2139/ssrn.1691869.
Forum Ekonomi Dunia, Laporan Risiko Global, 2023, tersedia di https://www.weforum.org/reports/global-risks-report-2023?gclid=Cj0KCQjwn_OlBhDhARIsAG2y6zOzjl3RZjzSbIWBaeP57p4xwxr6YogFh4PjupHlYxdoPzcZNVNy4caAlbwEALw_wcB.
Young, S., 2013. Ekonomi Biaya Transaksi. Dalam: Idowu, SO, Capaldi, N., Zu, L., Das Gupta, A. (Eds.), Ensiklopedia Tanggung Jawab Sosial Perusahaan. Springer, Berlin Heidelberg.